

CompTIA Security+ Glossary

Estimated time needed: 20 minutes

Welcome to your CompTIA Security+ study glossary!

As part of your testing experience you need to be familiar with a multitude of terms. You need to know more than definitions, you need to apply the term in the context of the relevant security technology.

Getting Started

The CompTIA Security+ exam is organized into five domains. You'll find specific terms associated with each domain. Related exam questions apply the term in the context of resolving the related domain's security needs

This glossary organizes terms based on their appropriate domains, and includes a relevant example with each term.

What you will learn

After completing this reading, you will be able to:

- Define terms associated with each domain.
- Describe a relevant Security+ business use applicable to each term.

Let's get started!

Domain 1: General Security Concepts

Compare and contrast various types of security controls

Term	Definition	Contextual Example
Categories	Broad classifications that describe the nature and purpose of security controls.	Security controls are often categorized into technical, managerial, operational, and physical to streamline their implementation and management.
Compensating	Controls that provide an alternative method to achieve security goals when primary controls are not feasible.	If an organization cannot implement a complete encryption solution, it might protect sensitive data with compensating controls, such as strong access controls and logging.
Control types	Categories of security mechanisms designed to mitigate risks, enforce policies, and safeguard systems.	Organizations use preventive controls to stop threats before they occur. They use detective controls to identify incidents and corrective controls to restore systems after a breach. Other types include deterrent controls (discourage attacks), compensating controls (provide alternative protection), and directive controls (mandate actions or policies).
Corrective	Controls that respond to and rectify security incidents after they have occurred.	After a data breach, an organization might implement corrective controls such as patching vulnerabilities and updating security protocols to prevent future incidents.
Detective	Controls that identify and alert organizations to security incidents as they occur.	Intrusion detection systems (IDS) monitor network traffic and alert administrators to suspicious activities, serving as detective controls.
Deterrent	These controls are designed to discourage individuals from attempting to breach security measures.	Warning signs indicating that surveillance cameras are in use act as deterrent controls, making potential intruders think twice before attempting to breach security.
Directive	Controls that guide employee behavior and establish expectations for organizational security practices.	A security awareness training program that educates employees on phishing attacks serves as a directive control, guiding them on recognizing and responding to security threats.
Managerial	Controls that focus on managing security policies, procedures, and compliance through organizational practices.	A company's security policy and employee training programs are managerial controls that ensure security protocols are followed.
Operational	Controls that involve day-to-day operations and processes to ensure security is maintained.	Regular security audits and incident response drills are operational controls that help an organization respond effectively to security threats.
Physical	Security measures designed to protect physical assets and facilities from unauthorized access or damage.	Access control systems, such as key cards or biometric scanners, are physical controls that restrict entry to sensitive areas.
Preventive	These controls are aimed at stopping security incidents before they occur.	Installing antivirus software and performing regular updates are preventive controls that help protect systems from malware attacks.
Technical	Refers to security measures that involve technology and software to protect information systems.	Firewalls and encryption are examples of technical controls used to safeguard data during transmission over networks.

Summarize fundamental security concepts

Term	Definition	Contextual Example
Access badge	A physical card or token authorized personnel used to gain access to restricted areas.	Employees must scan their access badges at entry points to unlock doors and access secure areas within an office.
Access control vestibule	An enclosed area that restricts access to a building, requiring identification before entry.	Many corporate offices use access control vestibules with security guards to verify identities before allowing entry.
Adaptive identity	The ability to adjust authentication methods based on the context and risk associated with access requests.	An organization can require multi-factor authentication for high-risk transactions, adapting to potential threats.
Authenticating people	The process of verifying the identity of a user attempting to access a system or service.	Requiring a username and password is a common method for authenticating users before granting access to a system.
Authenticating systems	The process of verifying the identity of devices or systems within a network to ensure secure communication.	Mutual TLS (Transport Layer Security) authenticates both the client and server in a secure connection.
Authentication, Authorization, and Accounting (AAA)	A framework for controlling access to resources by verifying identities, granting permissions, and tracking usage.	A bank uses AAA protocols to ensure that only authorized users can access their accounts and that their transactions are logged.
Authorization models	Frameworks that determine how access rights are granted to users and systems.	Role-Based Access Control (RBAC) grants permissions based on user roles within an organization, simplifying management.
Availability	The guarantee that systems and data are accessible when needed by authorized users.	Implementing redundant servers and backups ensures high availability of services during outages.
Bollards	Short, sturdy vertical posts control vehicle access to certain areas and protect infrastructure.	Bollards are often used in front of government buildings to prevent unauthorized vehicle entry and enhance security.
Confidentiality	The principle of ensuring that sensitive information is not disclosed to unauthorized individuals.	Encrypting emails to protect personal information is a common practice to maintain confidentiality.
Control plane	The component of a network or system responsible for managing and directing traffic, implementing security policies, and making decisions about data flows.	In a zero-trust architecture, the control plane ensures that only authenticated and authorized users can access sensitive resources by dynamically applying security policies based on real-time user behavior and network conditions.
Data plane	The part of a network responsible for the actual data transfer and processing of user requests.	The data plane handles the flow of data packets while enforcing policies established by the control plane.
Deception and disruption technology	These are security technologies designed to mislead and disrupt potential attackers by creating fake resources.	Using a honeypot to lure cyber attackers away from real systems allows security teams to analyze and respond to threats.
Fencing	Barriers are constructed to prevent unauthorized physical access to a facility or area.	Chain-link fencing around a data center provides a physical barrier against unauthorized intruders.
Gap analysis	The process of comparing actual performance with potential performance to identify discrepancies in security measures.	A company conducts a gap analysis to evaluate its current cybersecurity measures against industry best practices.
Honeyfile	A file planted in a system that appears valuable but is designed to alert administrators if accessed.	A company might place a honeyfile labeled "Confidential Financial Data" to trigger an alert if someone attempts to open it.
Honeynet	A network of honeypots designed to simulate a real environment, capturing a broader range of attack data.	Security researchers deploy a honeynet to study advanced persistent threats (APTs) by observing how attackers interact with multiple decoy systems.
Honeypot	A decoy system designed to attract and detect unauthorized access attempts or malicious activity.	A honeypot can mimic a vulnerable server to monitor attacker behavior and gather intelligence on security threats.
Honeytoken	A piece of data that appears legitimate but serves as a trap to detect unauthorized access or misuse.	Using a honeytoken, such as a fake user account, allows security teams to monitor unauthorized attempts to access sensitive resources.
Implicit trust zones	Areas within a network that are automatically trusted without verification can pose security risks.	Legacy systems that trust all traffic within the corporate network can create implicit trust zones vulnerable to attacks.
Infrared	A type of sensor that detects heat emitted by objects and is often used in security systems for motion detection.	Infrared sensors are commonly used in alarm systems to trigger alerts when detecting unauthorized movement.
Integrity	The assurance that data is accurate and unaltered, except by authorized users.	Hashing files can ensure data integrity, allowing users to verify that the file has not been modified since its creation.
Lighting	The strategic use of light enhances security by illuminating areas and deterring criminal activity.	Motion-activated lighting around a building's perimeter increases visibility and discourages unauthorized access at night.
Microwave	Sensors that use microwave signals to detect motion and are often used in security systems.	Microwave sensors can be used in outdoor security systems to detect movement across large areas.

Term	Definition	Contextual Example
Non-repudiation	A security principle that prevents individuals from denying their actions related to data or transactions.	Digital signatures provide non-repudiation, allowing the sender to prove that they sent a message or transaction.
Physical security	Measures designed to protect physical assets from unauthorized access or damage.	Installing security cameras and hiring security personnel are components of a comprehensive physical security strategy.
Policy administrator	The individual or system responsible for managing security policies and access controls.	A cybersecurity manager is the policy administrator, ensuring access controls align with organizational security goals.
Policy enforcement point	The point within a network where access control policies are applied and enforced.	A firewall acts as a policy enforcement point, blocking unauthorized access based on established security rules.
Policy engine	The component evaluates access requests against defined security policies to determine access rights.	In a zero-trust architecture, the policy engine assesses requests based on user identity and context before granting access.
Policy-driven access control	Access control mechanisms that are governed by established security policies.	Using predefined security policies, an organization can automatically grant or deny access to resources based on user roles.
Pressure	Sensors that detect changes in pressure are often used to detect unauthorized access or breaches.	Pressure mats can be placed in secure areas to alert security personnel if someone steps on them.
Security guard	A trained individual monitors and protects property and individuals from unauthorized access or threats.	Security guards are stationed at entrances to monitor access and respond to security incidents in corporate environments.
Sensors	Devices use these devices to detect specific physical changes or intrusions in a secure area.	Infrared sensors can trigger alarms if motion is detected in restricted areas after hours.
Subject/System	The entities involved in a security policy where a subject is a user or system requesting access, and the system is the resource being accessed.	In access control, the subject (a user) requests access to a system (a database) based on defined policies.
Threat scope reduction	Measures taken to limit the potential impact of security threats on an organization.	Segmenting networks to isolate sensitive data reduces the threat scope in case of a breach.
Ultrasonic	Sensors that use sound waves to detect motion and changes in the environment are commonly used in security.	Ultrasonic sensors can be employed in security systems to create invisible barriers that trigger alarms if breached.
Video surveillance	Video cameras that monitor and record activity in and around a facility for security purposes.	Retail stores utilize video surveillance systems to deter theft and monitor customer behavior.
Zero trust	A security model that requires strict identity verification for every person and device attempting to access resources, regardless of whether they are inside or outside the network perimeter.	In a zero-trust environment, all access requests must be authenticated and authorized, even for users within the corporate network.

Explain the importance of change management processes and their impact on security

Term	Definition	Contextual Example
Allow lists/deny lists	These security mechanisms specify which entities are allowed or denied access to specific resources or services.	An organization uses an allow list to permit only trusted IP addresses to access its internal applications, enhancing security.
Application restart	The action of closing and reopening an application to implement updates or fixes.	Restarting the application is required after applying security patches to ensure vulnerabilities are addressed.
Approval process	A defined workflow that requires authorization before proceeding with changes or actions within the organization.	New security protocols must go through an approval process that includes reviews by IT and compliance teams.
Backout plan	A predefined strategy for reversing changes in case an implementation fails or causes issues.	A backout plan was activated to restore previous configurations after the deployment of a new security software caused system instability.
Business processes impacting security operation	Procedures and workflows within an organization that can affect security measures and incident response.	An approval process for new software purchases can impact security operations by ensuring that organization only used compliant tools.
Dependencies	Relationships between systems or components where one relies on another for functionality or data access.	A new security feature might have dependencies on existing systems, requiring careful coordination during implementation.
Documentation	The process of creating and maintaining records that describe systems, policies, and procedures for reference and compliance.	Updating documentation after a system upgrade ensures that all users have access to current procedures and security protocols.
Downtime	Periods when a system or service is unavailable due to maintenance, updates, or unexpected failures.	Scheduled downtime for system updates is communicated to users in advance to minimize disruption to business operations.

Term	Definition	Contextual Example
Impact analysis	The process of evaluating the potential effects of changes to security operations on business functions.	Conducting an impact analysis before implementing new security measures helps ensure minimal disruption to critical business operations.
Legacy applications	Outdated software systems that are still in use but might not be fully supported or compliant with current security standards.	Legacy applications often require additional security measures to protect against vulnerabilities due to their outdated technology.
Maintenance window	A scheduled time period is allocated for performing updates or repairs to systems without impacting normal operations.	The organization scheduled a maintenance window over the weekend to apply critical security patches to all servers.
Ownership	The designation of responsibility for specific assets, processes, or data within an organization.	Data ownership defines who is accountable for maintaining the security and integrity of sensitive customer information.
Restricted activities	Actions that are limited or prohibited to reduce risk and enhance security posture within an organization.	Remote access to sensitive systems can be a restricted activity to minimize exposure to potential threats.
Service restart	The process of stopping and starting a service to apply changes or resolve issues.	A service restart is performed after updating the security software to ensure the new configurations take effect.
Stakeholders	Individuals or groups that have an interest in or are affected by security operations and decisions.	Stakeholders in a security project can include IT staff, management, compliance officers, and end-users who rely on secure systems.
Standard operating procedure (SOP)	A set of step-by-step instructions that outlines how to perform specific tasks to ensure consistency and quality in operations.	An SOP for incident response provides detailed steps for detecting, reporting, and addressing security incidents systematically.
Technical implications	The consequences or effects that changes in technology or systems can have on security operations and policies.	The migration to a cloud-based service has technical implications, including changes to data encryption and access controls.
Test results	Outcomes of security testing, including assessments, audits, and penetration tests, which provide insights into vulnerabilities and effectiveness.	Test results from a recent security audit revealed critical vulnerabilities in the network configuration that need immediate attention.
Updating diagrams	The practice of revising visual representations of systems and processes to reflect current configurations or workflows.	Network diagrams are updated to include new security appliances and reflect system architecture changes.
Updating policies/procedures	The process of revising organizational rules and guidelines to address new risks, technologies, or regulatory requirements.	Updating security policies after a data breach ensures that lessons learned are integrated into future practices.
Version control	A system for managing changes to documents, software, or other information, allowing for tracking of revisions and collaboration.	Version control systems help teams track changes to security documentation, ensuring that all team members are working with the most current information.

Explain the importance of using appropriate cryptographic solutions

Term	Definition	Contextual Example
Asymmetric encryption	An encryption method that uses a pair of keys (public and private) for secure communication.	Asymmetric encryption allows for the exchange of secure data without sharing private keys, enhancing security.
Blockchain	A decentralized and distributed digital ledger technology that securely records transactions across multiple computers.	Blockchain technology underpins cryptocurrencies like Bitcoin, providing a secure method for recording transactions.
Certificate authorities	Trusted entities that issue digital certificates and verify the identities of organizations or individuals.	Certificate authorities, such as Let's XYZ Infocom, provide SSL certificates to websites, enabling secure connections.
Certificate revocation lists (CRLs)	Lists maintained by certificate authorities to identify revoked certificates that are no longer valid.	CRLs are used by web browsers to check if an SSL certificate has been revoked before establishing a secure connection.
Certificate signing request (CSR) generation	The process of creating a request for a digital certificate that includes the public key and identity information.	Organizations generate a CSR to obtain an SSL certificate from a certificate authority, ensuring secure website connections.
Certificates	Digital documents that verify the identity of entities and bind them to cryptographic keys.	SSL certificates secure website communications, ensuring that users are connected to legitimate services.
Data masking	The technique of obscuring specific data within a database to protect sensitive information from unauthorized access.	Data masking is often used in non-production environments to protect sensitive customer data during testing.
Database encryption	The encryption of database files protects sensitive data stored in databases from unauthorized access.	Implementing database encryption helps secure customer information stored in an e-commerce platform.
Digital signatures	A cryptographic technique is used to verify the authenticity and integrity of a message or document.	Digital signatures ensure that an email is from the claimed sender and has not been altered during transmission.

Term	Definition	Contextual Example
Encryption	The process of converting plain text into ciphertext to protect data from unauthorized access.	Encrypting sensitive data such as credit card information helps ensure it is secure during transmission.
File encryption	The process of encrypting individual files to protect their contents from unauthorized access.	Encrypting a financial report file ensures that only authorized users can view its contents.
Full-disk encryption	A method of encrypting all the data on a disk drive to protect information from unauthorized access.	Full-disk encryption is commonly used on laptops to safeguard data if the device is lost or stolen.
Hardware security module (HSM)	A dedicated hardware device that manages and protects cryptographic keys, providing a secure environment for encryption operations.	Financial institutions often use HSMs to safeguard sensitive transaction data and cryptographic keys.
Hashing	The process of converting data into a fixed-size string of characters unique to the original data.	Hashing passwords ensures that even if the database is compromised, the actual passwords remain secure and unrecoverable.
Key escrow	A method of storing a copy of a private key with a third party to allow recovery if the original is lost.	Organizations often use key escrow services to ensure that encrypted data can be accessed in emergencies.
Key exchange	The process of securely sharing cryptographic keys between parties to enable encrypted communication.	The Diffie-Hellman method is a popular key exchange protocol that allows two parties to generate a shared key securely.
Key length	The key length is the size of the cryptographic key that influences the strength and security of the encryption.	Longer key lengths, such as 256 bits, are typically more secure and harder to crack than shorter keys.
Key management system	A system that manages the generation, distribution, storage, and revocation of cryptographic keys.	A key management system helps organizations maintain security by ensuring proper key lifecycle management.
Key stretching	A technique that increases the security of a key by applying a cryptographic function multiple times.	Key stretching makes brute-force attacks more difficult by increasing the time required to test each key candidate.
Obfuscation	This is a technique used to make data unintelligible or difficult to understand without proper authorization.	Obfuscation techniques might involve altering code or data formats to prevent unauthorized access while preserving functionality.
Online Certificate Status Protocol (OCSP)	A protocol is used to obtain the revocation status of a digital certificate in real time.	OCSP allows browsers to verify the validity of a certificate quickly, enhancing security during online transactions.
Open public ledger	A transparent and accessible record of transactions that anyone can view is typically associated with blockchain technology.	Open public ledgers enable users to verify transactions without relying on a central authority, enhancing trust.
Partition encryption	The encryption of specific partitions on a storage device to protect sensitive data stored within those areas.	Encrypting a partition that contains confidential business documents provides an additional layer of security.
Private key	A secret cryptographic key is used to decrypt data encrypted with the corresponding public key.	A user keeps their private key secure, using it to decrypt messages received with their public key.
Public key	A cryptographic key that can be shared publicly and used to encrypt data or verify digital signatures.	In a PKI system, users share their public keys with others to enable secure communication.
Public key infrastructure (PKI)	A framework that manages digital certificates and public-key encryption to secure communications and transactions.	PKI is used in secure email communication, ensuring that only intended recipients can decrypt messages.
Record encryption	The encryption of individual records within a database or data file enhances security at a granular level.	Record encryption can protect sensitive customer records while allowing other data to remain accessible.
Root of trust	The foundation of a security system that establishes the legitimacy of entities and certificates within the system.	The root of trust is crucial for PKI, as it verifies the authenticity of certificates issued by trusted authorities.
Salting	The practice of adding a random value (salt) to input data before hashing to protect against precomputed attacks.	Salting passwords before hashing prevents attackers from using rainbow tables to crack password hashes.
Secure enclave	A secure area within a processor that protects sensitive data and operations from unauthorized access.	Secure enclaves, such as fingerprints and facial recognition, are utilized in mobile devices to protect biometric data.
Self-signed	This certificate is signed by the entity that created it rather than a trusted certificate authority.	Self-signed certificates are often used for internal testing but are not trusted by browsers for public-facing websites.
Steganography	This is the process of hiding data within other non-secret data, making it difficult to detect the hidden	Using steganography, a secret message can be concealed within an image file without altering its visible appearance.

Term	Definition	Contextual Example
	information.	
Symmetric encryption	An encryption method that uses the same key for data encryption and decryption.	Symmetric encryption is faster and often used for encrypting large amounts of data, such as files or databases.
Third-party	This term refers to entities that are not directly involved in a transaction or communication but play a role in security or certification.	Third-party certificate authorities validate the identities of organizations, providing trusted certificates for secure transactions.
Tokenization	The replacement of sensitive data with non-sensitive equivalents (tokens) that can be used in its place.	Tokenization is used in payment processing to replace credit card numbers with unique tokens, enhancing security.
Transport/communication encryption	Encrypting data is transmitted over networks to protect it from interception during transit.	HTTPS uses transport encryption to secure web traffic, ensuring that user data is protected while being transmitted.
Trusted Platform Module (TPM)	A hardware-based security device that provides cryptographic functions and secure storage of keys.	Computers often use TPM to ensure secure boot and hardware-based encryption capabilities.
Volume encryption	This is the process of encrypting entire volumes (logical storage areas) on a disk to safeguard all data.	Volume encryption is often used to protect external hard drives containing sensitive information.
Wildcard	A type of digital certificate that can secure an unlimited number of subdomains under a single main domain.	A company uses a wildcard SSL certificate to secure multiple subdomains, such as shop.example.com, blog.example.com, and mail.example.com, all with one certificate, reducing administrative overhead and cost.

Domain 2: Threats, Vulnerabilities, and Mitigations

Compare and contrast common threat actors and motivations

Term	Definition	Contextual Example
Blackmail	Using sensitive information to extort money or compel compliance with a threat actor's demands.	After infiltrating a company's network, an attacker may exfiltrate sensitive employee data and then blackmail the organization, threatening to release this information publicly unless a significant ransom is paid, creating a coercive environment.
Data exfiltration	Malicious actors typically perform the unauthorized data transfer from a network for theft or espionage.	An insider threat may exfiltrate sensitive data by secretly copying client lists to a USB drive and planning to sell this information to competitors. This could lead to severe financial losses and reputational damage for the organization.
Disruption/Chaos	The intent is to create confusion, destruction, or operational disruption, often without financial or political motives.	Some attackers motivated by disruption might target a city's power grid to induce widespread blackouts, causing chaos without any clear financial gain. They simply aim to create confusion and disarray among the public.
Espionage	Spying to acquire confidential information is typically conducted by nation-states or competitive organizations.	A nation-state might engage in cyber espionage to infiltrate a rival corporation's network, stealing trade secrets related to groundbreaking technology. Thus, it would gain a significant competitive edge in the marketplace and advance national interests.
Ethical	Actors claiming to operate based on moral principles are sometimes associated with ethical hacking or whistleblowing.	Some insiders might leak confidential data to expose corporate wrongdoing, justifying their actions as ethical based on a belief that the public has a right to know about harmful practices, thereby holding the organization accountable.
External threat	Threat actors outside the organization, such as cybercriminals or nation-state actors, lack direct access.	External actors, such as cybercriminal groups, might attempt to breach an organization's network by exploiting weaknesses in its firewall, aiming to steal sensitive customer information for identity theft or financial fraud.
Financial gain	This is a common motivation for cybercriminals seeking to profit through theft, fraud, or extortion.	Organized crime syndicates often target financial institutions with sophisticated phishing schemes. They aim to gain financial gain by stealing account credentials and transferring funds to their own accounts without detection.
Hacktivist	An individual or group that employs hacking techniques to promote political or social causes.	A hacktivist collective might deface a government website during a significant political protest, using its hacking skills to raise awareness about human rights violations and draw public attention to its cause through digital activism.
Insider threat	A current or former employee, contractor, or partner who uses authorized access to harm the organization.	A disgruntled employee who feels undervalued may steal sensitive customer data before leaving the company, intending to sell it to competitors or use it for personal gain, breaching trust and compromising organizational integrity.
Internal threat	Threat actors, such as employees, contractors, or partners.	An internal actor could be an employee who intentionally leaks proprietary information to a rival firm, motivated by financial incentives or personal grievances against the organization, undermining competitive advantages.
Level of sophistication	The expertise and complexity of methods employed by a threat actor can range from basic to highly advanced.	Organized crime groups often operate with a high level of sophistication, employing advanced malware, social engineering tactics, and coordinated attacks to bypass security defenses and maximize their chances of success.
Nation-state	A government-sponsored group or individuals conducting cyberattacks for	A nation-state actor might orchestrate cyberattacks to steal intellectual property from foreign corporations, aiming to boost their domestic industries and gain an economic

Term	Definition	Contextual Example
	political, economic, or military objectives.	advantage in global markets. The actor may also target the critical infrastructure of rival nations to create instability.
Organized crime	Groups of criminals engage in cybercrime for financial gain, often utilizing sophisticated techniques and resources.	Organized crime syndicates might execute ransomware attacks on healthcare providers, encrypting patient data and demanding hefty ransoms. These attacks can threaten lives by disrupting critical services and extorting money from vulnerable institutions.
Philosophical/political beliefs	Motivations rooted in personal ideologies are often seen in hacktivism.	A hacktivist may launch a cyberattack against a corporation accused of environmental violations, seeking to disrupt its operations and promote awareness of its practices, thereby aligning its actions with its personal beliefs and advocacy goals.
Resources/funding	The financial and technological resources available to a threat actor influence their capabilities and reach.	A nation-state threat actor may have access to vast financial and technological resources, allowing them to deploy sophisticated cyber espionage campaigns over extended periods, surpassing the capabilities of independent hackers or small criminal groups.
Revenge	A personal motive where an individual seeks retaliation against an organization is frequently observed in insider threats.	An unjustly terminated employee may retaliate against the company by launching a cyberattack, deleting crucial files, or leaking sensitive information to the public as an act of revenge, damaging the organization's reputation and operations.
Service disruption	An attack aimed at interrupting the availability of services, resulting in operational and financial damage.	A distributed denial-of-service (DDoS) attack could paralyze a significant e-commerce website during peak shopping hours, resulting in substantial financial losses and damaging customer trust due to prolonged downtime and service unavailability.
Shadow IT	Employees may make unauthorized use of IT resources and applications without official approval from the organization.	Employees may use unapproved cloud storage solutions to share files, exposing sensitive company data to potential breaches. These services may need proper security measures and oversight from the IT department.
Threat actors	Individuals or groups that pose a risk to an organization by launching cyberattacks or exploiting vulnerabilities.	Organizations face a variety of threat actors, including nation-states that engage in cyber espionage to gather sensitive information, hacktivist groups that deface websites in protest, and insider threats that exploit their access for personal gain.
Unskilled attacker	Individuals with limited technical skills often use pre-built tools or scripts to exploit known vulnerabilities.	An unskilled attacker might employ publicly available tools like Metasploit to exploit common vulnerabilities on unsecured websites, taking advantage of widely known exploits without understanding the underlying technology.
War	Cyberattacks are conducted as part of a military or political conflict, aiming to weaken an adversary's capabilities.	During a military conflict, nation-state actors may launch cyberattacks against critical infrastructure, such as power grids or communication networks, to disrupt the enemy's military operations, demonstrating the role of cyber warfare in modern conflicts.

Explain common threat vectors and attack surfaces

Term	Definition	Contextual Example
Agentless attack vector	Security or management systems that do not require client-side installation but rely on remote connections can pose risks.	An agentless monitoring tool can have vulnerabilities in its remote connection protocols, allowing attackers to intercept data and gain unauthorized access to the systems it monitors.
Bluetooth attack vector	Attackers for unauthorized device access often target a wireless protocol for short-range communication.	An attacker exploits a Bluetooth vulnerability to connect to a nearby smartphone without authorization, potentially accessing personal information or injecting malware.
Brand impersonation attack vector	When attackers mimic a trusted brand's identity to deceive individuals into providing sensitive information or credentials.	A brand impersonation email resembles a legitimate message from a well-known company, tricking users into clicking malicious links that lead to credential theft or malware downloads.
Business email compromise attack vector	A type of impersonation attack where attackers spoof email accounts to deceive companies into making fraudulent payments.	In a BEC attack, an attacker impersonates a CEO via email and requests a wire transfer to a fraudulent account, exploiting the trust of the employees responsible for financial transactions.
Client-based attack vector	Systems requiring client-side software to operate can be vulnerable if the client application has security flaws.	A client-based application for managing finances can have unpatched vulnerabilities, allowing an attacker to access sensitive financial data through a targeted exploit.
Default credentials attack vector	Preset usernames and passwords in devices or software are often left unchanged, making them easy targets for attackers.	Many IoT devices are compromised because users fail to change default credentials, which allows attackers easy access to the devices' settings and capabilities.
Email-based attack vector	A communication method used for sending and receiving messages over the internet, often exploited in phishing campaigns.	An attacker sends a fraudulent email that appears to be from a trusted bank. The email prompts recipients to click a link to verify their account, ultimately leading them to a phishing site designed to capture their login credentials.
File-based attack vector	Exploiting files, such as PDFs or documents, to carry and execute malicious code when opened.	A PDF file sent via email that is a legitimate invoice contains a malicious macro that runs code when the user opens it, compromising their system.
Human vectors attack vector	Attack methods that exploit human behavior, such as social engineering, to manipulate individuals into disclosing information.	Phishing emails are a common example of using human vectors to trick users into revealing passwords. They can appear to be legitimate requests from trusted sources.

Term	Definition	Contextual Example
Image-based attack vector	Attacks use images containing hidden malicious code to exploit vulnerabilities in viewing software.	An attacker embeds harmful scripts in a seemingly harmless .jpg image. When the user opens the image, the script executes, potentially installing malware on their system.
Impersonation attack vector	An attack method where the perpetrator pretends to be a trusted entity to deceive individuals and gain access to information.	An attacker impersonates a company executive in an email to request sensitive documents from employees, exploiting trust to gain confidential information.
Instant messaging attack vector	Real-time communication through apps or platforms like WhatsApp or Slack can be exploited for phishing or malware.	An attacker sends a link via WhatsApp that claims to be a new feature update, but when clicked, it downloads malware onto the victim's device.
Managed service provider attack vector	Third-party companies providing IT services can become attack vectors if their security is compromised.	Attackers often target MSPs to access the networks of multiple clients through a single entry point, exploiting vulnerabilities in the MSP's systems.
Message-based attack vector	Attack vectors that leverage communication methods such as email, SMS, and instant messaging to deliver malicious content.	A phishing email with a malicious attachment disguised as an important document from a known colleague can trick users into downloading malware, compromising their credentials and sensitive information.
Misinformation/disinformation attack vector	False information spread intentionally or unintentionally is often used to manipulate public perception or cause confusion.	Attackers spread disinformation online to sow confusion during elections or disrupt organizational operations by creating fake news stories that mislead the public.
Open service ports attack vector	Network ports left open and unsecured provide potential entry points for attackers to exploit.	Leaving open service ports exposed without proper firewall rules increases the risk of external attacks, such as unauthorized access or data breaches.
Phishing attack vector	A type of social engineering where attackers send fraudulent messages designed to trick individuals into divulging information.	A phishing email from a bank can deceive users into entering their login credentials on a fake website, leading to unauthorized access to their accounts.
Pretexting attack vector	A social engineering tactic where attackers create a fabricated scenario to manipulate individuals into revealing sensitive information.	In a pretexting scam, an attacker pretends to be from tech support, convincing users to disclose their login credentials under the guise of assisting.
Removable device attack vector	Physical devices like USB or external hard drives can carry malware and infect systems when plugged in.	A USB stick labeled "Confidential Report" is left in a public area. When an unsuspecting user plugs it into their computer, it installs malware that compromises the system's security.
Smishing attack vector	Phishing attacks are conducted through SMS text messages, often involving fraudulent links or urgent requests for personal information.	A smishing message appears to come from a financial institution. It urgently requests sensitive data via text to verify account information, leading users to a fraudulent website.
SMS-based attack vector	A text messaging service on mobile phones, often targeted by attackers through smishing, is a type of social engineering.	An SMS that appears to be from a bank asks the recipient to confirm recent transactions by clicking a link, which redirects them to a fraudulent website that collects their personal information.
Supply chain attack vector	The network of vendors, suppliers, and service providers can introduce security risks if compromised.	A breach at a managed service provider (MSP) can expose its client companies to potential security threats as attackers gain access through a trusted third party.
Typosquatting attack vector	A form of cyberattack where attackers register domain names similar to legitimate ones, relying on common typing errors.	An attacker uses typosquatting by registering a domain like "goolge.com", hoping users mistype "google.com" and visit the fake site, which can steal their login information or distribute malware.
Unsecure networks attack vector	Networks without sufficient security measures expose them to attacks such as eavesdropping and man-in-the-middle (MITM).	An attacker intercepts data transmitted over an unsecured public Wi-Fi network, capturing sensitive information such as passwords and personal messages from unsuspecting users.
Unsupported systems attack vector	Legacy systems and applications no longer receive security updates, making them highly vulnerable to attacks.	Unsupported systems like Windows XP, which no longer receive updates, are prime targets for attackers looking to exploit unpatched vulnerabilities for unauthorized access.
Vendor attack vector	Suppliers of products or services can introduce risks if their systems are compromised or poorly managed.	An attacker compromises a vendor providing software updates, inserting malware into the supply chain that affects all clients receiving the updates.
Vishing attack vector	A form of voice phishing where attackers use phone calls to impersonate legitimate entities and steal personal information.	A vishing call from someone claiming to be from tech support could trick victims into providing access to their systems or personal details.
Voice call attack vector	Using phone calls to carry out attacks like vishing, where attackers pose as legitimate institutions to steal information.	An attacker calls a victim, impersonating a customer service representative from a known tech company, and tricks them into providing sensitive information under the guise of verifying their account.
Vulnerable software attack vector	Attackers can exploit software with known or unknown security flaws to gain unauthorized access.	Attackers target vulnerable software, such as an unpatched version of a web browser, exploiting its flaws to execute malicious scripts and gain access to user data.

Term	Definition	Contextual Example
Watering hole attack vector	A cyberattack is where attackers compromise a website frequently visited by the intended target to deliver malware.	Attackers might conduct a watering hole attack by compromising an industry-related website, infecting visitors from a specific organization with malware tailored to exploit their systems.
Wired attack vector	Physical cabling for network communication, which, if unprotected, can be tapped into for eavesdropping or data interception.	An attacker taps into an unsecured network cable in an office building, allowing them to intercept sensitive data transmitted across the network.
Wireless attack vector	Communication via radio frequencies can be susceptible to attacks like eavesdropping or Wi-Fi password cracking.	Attackers use a Wi-Fi sniffer to capture unencrypted data transmitted over an open wireless network, gaining access to sensitive information such as login credentials.

Explain various types of vulnerabilities

Term	Definition	Contextual Example
Application security	Vulnerabilities that compromise the integrity and functionality of software applications.	Application-level attacks, such as memory injection or buffer overflow, can undermine system integrity, potentially leading to data breaches or application crashes.
Buffer overflow	A vulnerability occurs when a program writes more data to a buffer than it can hold, risking arbitrary code execution.	An attacker exploits a buffer overflow by feeding excessive data into an input field, causing the application to crash or execute malicious code.
Cloud-specific vulnerability	Security threats are unique to cloud environments, often stemming from insecure configurations or poor access control.	Misconfigured cloud storage settings can expose sensitive data to unauthorized users, leading to potential breaches and compliance violations.
Cross-site scripting (XSS)	A vulnerability where attackers inject malicious scripts into websites, executed by unsuspecting users' browsers.	An attacker exploits XSS by embedding harmful JavaScript into a webpage. The script executes in the browser of any user who visits the page, potentially stealing their data.
Cryptographic	Vulnerabilities stemming from weaknesses in encryption methods or cryptographic protocols.	Flaws in cryptographic algorithms, such as weak encryption keys, can make sensitive data easier for attackers to decrypt, compromising confidentiality.
End-of-life	Devices or software no longer receiving updates or support render them vulnerable to threats.	End-of-life devices are susceptible to exploitation due to the lack of security patches and updates, making them attractive targets for attackers.
Firmware	Low-level software embedded in hardware devices that can be exploited if not regularly updated.	An attacker exploits outdated firmware in a router to gain unauthorized access to the network, compromising all connected devices.
Hardware provider	Suppliers of physical components that may introduce vulnerabilities through faulty or insecure hardware.	An insecure hardware provider may distribute compromised devices, enabling attackers to exploit the weaknesses in those devices for unauthorized access.
Hardware vulnerability	Vulnerabilities associated with physical devices, firmware, and hardware components.	Firmware vulnerabilities in network routers or legacy hardware can expose systems to serious security risks, allowing attackers unauthorized control.
Jailbreaking	Removing restrictions on a device's operating system to allow unauthorized software installation increases security risks.	Jailbreaking an iPhone allows users to install unauthorized apps, making the device more vulnerable to malware and other security threats.
Legacy	Outdated hardware or software still in use but no longer supported, posing significant security risks.	Running legacy systems like Windows XP significantly increases the risk of exploitation due to unpatched vulnerabilities that attackers can easily target.
Malicious update	A security threat where legitimate software updates are tampered with to introduce malicious code.	During routine patching, a compromised software update introduces backdoors into a previously secure system, allowing attackers ongoing access.
Memory injection	An attack technique where malicious code is inserted into a program's memory to alter its behavior.	An attacker uses memory injection to introduce harmful code into an application, resulting in unauthorized access or application crashes.
Misconfiguration	Incorrect settings in software, networks, or devices that expose them to potential exploitation.	A firewall misconfiguration leaves sensitive data accessible to unauthorized users, potentially leading to breaches and compliance issues.
Mobile device	Security risks specific to smartphones and tablets, including app vulnerabilities and insecure settings.	Mobile device vulnerabilities, such as jailbreaking or installing malicious apps, can expose sensitive personal data to unauthorized access or theft.
Operating system (OS)-based vulnerability	Vulnerabilities specific to the operating system potentially compromise the system's overall security.	Attackers often target unpatched OS vulnerabilities in Windows or Linux to escalate their privileges and gain deeper access to the system.
Race conditions	Vulnerabilities that arise when the behavior of a system depends on the timing or sequence of events.	An attacker manipulates the timing of events in a multi-threaded application, exploiting race conditions to bypass security checks and gain unauthorized access.
Resource reuse	Using resources in virtual environments without proper sanitization exposes sensitive data.	If resource reuse is not managed correctly, sensitive data from one virtual machine session could be accessed by another user, leading to data leaks.

Term	Definition	Contextual Example
Service provider vulnerability	A third-party company offering IT services can introduce vulnerabilities if their security is compromised.	A compromised service provider can lead to widespread security risks across their client base, potentially exposing sensitive data across multiple organizations.
Side loading	Installing apps from unofficial sources, bypassing official app stores, increasing security risks.	Users who use side-loading apps on Android devices may inadvertently install malware from untrusted sources, compromising device security.
Software provider	Third-party companies that supply software can introduce vulnerabilities if their products are compromised.	A software provider could inadvertently distribute malware-infected updates to clients, resulting in widespread security breaches across their user base.
Structured Query Language Injection (SQLi)	An attack that manipulates a database query through unsanitized user input, leading to data exposure or modification.	During a SQL injection attack, an attacker sends malicious SQL commands to a web application, potentially exposing sensitive customer data stored in the database.
Supply chain vulnerability	Vulnerabilities arise from third-party hardware, software, or service providers within a company's supply chain.	Supply chain attacks compromise third-party software updates, potentially introducing malicious code that affects the end customer's security.
Time-of-check (TOC)	A type of race condition where the vulnerability exists between verifying and using a resource.	An attacker takes advantage of a TOC vulnerability by altering a file/resource after it has been checked for validity but before it is used, leading to unauthorized actions.
Time-of-use (TOU)	A race condition vulnerability arises between the validation and execution of a resource.	In a TOU attack, an attacker modifies an authenticated file or resource immediately before it is executed, compromising the application's intended operation.
Virtual machine (VM) escape	An attack where malware escapes from a virtual machine to affect the host system or other VMs.	A VM escape vulnerability allows an attacker to move from a compromised virtual environment to the host system, compromising sensitive data and applications.
Virtualization	Security risks associated with virtual environments, including virtual machines (VMs) and hypervisors.	VM escape occurs when a malicious actor successfully breaks out of a virtual machine to compromise the underlying host system, leading to broader system vulnerabilities.
Web-based vulnerability	Security threats that specifically target websites and web applications, often through malicious input or design flaws.	SQL injection (SQLi) and cross-site scripting (XSS) are common web-based vulnerabilities that can lead to unauthorized data access or manipulation.
Zero-day	A vulnerability that is unknown to the software vendor and is actively being exploited before a fix is available.	Zero-day vulnerabilities pose a significant threat, as attackers can exploit them without fear of immediate detection or patching, leading to potential widespread damage.

Given a scenario, analyze indicators of malicious activity

Term	Definition	Contextual Example
Account lockout	A condition triggered when multiple failed login attempts are detected, potentially indicating a brute force attack.	Multiple failed login attempts led to an account lockout, signaling a possible brute-force attack on the security team.
Amplified DDoS	A DDoS attack that uses reflective servers to multiply traffic, increasing the attack's impact.	Attackers launch an amplified DDoS attack by exploiting publicly accessible DNS servers to send overwhelming traffic to the victim's server, disrupting services.
Birthday attack	A cryptographic attack that exploits the mathematics of probability to find two different inputs with the same hash value.	The birthday attack enables an attacker to discover two distinct messages that yield the same hash value, breaking the security of digital signatures.
Bloatware	Unwanted software that takes up system resources and can slow down performance.	A new laptop is delivered with pre-installed bloatware, which leads to noticeable reductions in processing speed due to unnecessary applications running in the background.
Brute force	Repeatedly trying different combinations of passwords or keys to gain unauthorized access.	A hacker employs a brute force attack on the admin account, systematically trying thousands of password combinations until they successfully gain access.
Collision attack	An attack where two different inputs produce the same cryptographic hash compromises data integrity.	A collision attack exploits weaknesses in a hashing algorithm, causing two files to generate the same hash value and thereby threatening data integrity.
Credential replay	Reusing stolen authentication credentials to gain unauthorized access to systems.	An attacker can use credential replay to log into a corporate VPN using previously stolen username and password pairs, bypassing security measures.
Distributed Denial-of-Service (DDoS)	An attack that overwhelms a target system or network with excessive traffic, making it unavailable.	The company's website suffers a DDoS attack. Thousands of compromised devices flood the server, crashing it and making it inaccessible to users.

Term	Definition	Contextual Example
Domain Name System (DNS) attack	Attacks that exploit vulnerabilities in DNS, such as DNS poisoning or hijacking.	A DNS attack redirects users trying to access a legitimate website to a fraudulent page, tricking them into entering their sensitive credentials.
Downgrade attack	Forcing a system to use a weaker encryption protocol or lower security level to exploit vulnerabilities.	An attacker performs a downgrade attack, coercing a system into reverting to a less secure encryption protocol, allowing them to decrypt sensitive communications.
Injection	An attack where untrusted input is sent to an application, causing it to execute unintended commands.	An SQL injection attack targets the company's database, enabling the attacker to extract sensitive customer information by submitting malicious queries.
Keylogger	Malware that records keystrokes, capturing sensitive information like passwords or credit card details.	A keylogger infects a user's system, logging every keystroke and sending the data to an attacker who uses it to steal banking information.
Logic bomb	Malicious code triggered by a specific event or condition, such as a date or user action.	An employee sets a logic bomb in the company's payroll system that deletes critical files if they are terminated.
Malicious code	Code is inserted into a system to perform unauthorized and harmful actions.	An attacker injects malicious code into the company's website, allowing them to steal customer data and alter web content.
On-path (Man-in-the-middle)	An attack is when the attacker secretly intercepts and relays communications between two parties.	In an on-path attack, a hacker intercepts communication between a user and an online banking site, capturing sensitive information such as login credentials.
Out-of-cycle logging	Unexpected or irregular system log entries can indicate malicious activity.	The system generates out-of-cycle log entries during non-business hours, raising suspicion of unauthorized access attempts.
Password spraying	An attack is when an attacker tries several commonly used passwords on many accounts to avoid detection.	An attacker conducts password spraying by testing common passwords like "123456" across multiple accounts and successfully accessing a vulnerable one.
Privilege escalation	An attack is where the attacker gains higher access privileges than they are authorized to.	Privilege escalation occurs when an attacker exploits a vulnerability to gain administrative rights on a server after compromising a standard user account.
Radio Frequency Identification (RFID) cloning	Copying data from RFID tags to gain unauthorized access.	An attacker uses RFID cloning techniques to duplicate a victim's access card, allowing them unauthorized entry to secure facilities.
Ransomware	Malicious software that encrypts a user's files and demands payment for decryption.	A hospital faces a ransomware attack in which critical patient data is encrypted, rendering systems unusable until the ransom is paid.
Reflected DDoS	A DDoS attack where traffic is sent to a third party and reflected toward the victim.	In a reflected DDoS attack, attackers send requests to open DNS resolvers, which reflect a massive volume of responses to the target server, overwhelming it.
Replay attack	An attacker intercepts and retransmits valid data to impersonate a user or system.	An attacker conducts a replay attack by capturing login packets and retransmitting them to authenticate without valid credentials.
Rootkit	Software that hides the presence of malware allows attackers to maintain control over the system.	A rootkit is installed on a compromised server, granting the attacker persistent access while evading detection by standard antivirus solutions.
Spyware	Malicious software that secretly monitors user activity and collects personal information.	Spyware is installed on a victim's computer. It captures keystrokes and transmits sensitive passwords to the attacker without the user's knowledge.
Trojan	A type of malware disguised as legitimate software that performs malicious actions once installed.	A user installs what appears to be a legitimate antivirus program. However, the software is a Trojan that steals sensitive user credentials.
Virus	Malware that attaches itself to a legitimate program and spreads when the infected program is executed.	A virus spreads through email attachments, corrupting important files and infecting other devices connected to the network.
Wireless attack	Security breaches targeting wireless networks, such as Wi-Fi eavesdropping or man-in-the-middle attacks.	A wireless attack occurs on an open Wi-Fi network, allowing the attacker to intercept and manipulate communication between users and the internet.
Worm	Self-replicating malware that spreads across networks without attaching to a host file.	A worm infects the organization's internal network, rapidly replicating and consuming bandwidth, which causes significant slowdowns in network performance.

Explain the purpose of mitigation techniques used to secure the enterprise

Term	Definition	Contextual Example
Access control	A security technique that regulates who or what can access resources in a computing environment.	Employees must use multifactor authentication to access the company's secure database, ensuring only authorized personnel can enter.
Access Control List (ACL)	A list of permissions that defines who or what can access an object and the actions they can perform.	The firewall's ACL is configured to allow only specific IP addresses from the corporate headquarters to access internal servers, blocking all other external connections.

Term	Definition	Contextual Example
Application allow list	A security policy that permits only pre-approved applications to run on a system or network.	The IT department implements an application list to ensure employees can only run authorized software, reducing the risk of malware infections.
Configuration enforcement	Ensuring that system configurations comply with security policies and standards.	Configuration enforcement tools verify that all servers meet the organization's security standards, preventing unauthorized changes to system settings.
Decommissioning	Safely retiring outdated or unused systems and hardware while securely handling data.	Before decommissioning an old server, the IT team securely wipes all storage devices to prevent unauthorized recovery of sensitive information.
Encryption	The process of converting data into a code to prevent unauthorized access.	The company implements full-disk encryption on all employee laptops to safeguard sensitive client information in the event of loss or theft.
Hardening techniques	Methods used to strengthen a system's security, such as disabling unnecessary services or changing defaults.	The IT department employs hardening techniques to enhance system security, such as installing antivirus software, changing default passwords, and turning off unused ports.
Isolation	Separating systems or applications from the rest of the network to limit potential damage from threats.	Following malware detection, the IT team isolates the infected server from the network to prevent the spread of the threat to other systems.
Least privilege	A security principle that grants users the minimum level of access needed to perform their tasks.	Employees are granted the least privileged access to ensure they can only access the resources necessary for their job functions, reducing the risk of unauthorized access.
Monitoring	Continuously observing systems and networks to detect and respond to security threats.	The security team uses monitoring tools that alert them to unusual traffic patterns, indicating a potential Distributed Denial-of-Service (DDoS) attack.
Patching	Applying updates to software to fix vulnerabilities and improve security.	The IT team regularly applies security patches to the company's web servers to fix vulnerabilities and protect against potential exploits.
Segmentation	Dividing a network or system into isolated sections enhances security and control access.	A company segments its network by department, allowing only HR staff to access payroll data, which isolates sensitive information from other teams.

Domain 3: Security Architecture

Compare and contrast the security implications of different architectural models.

Term	Definition	Contextual Example
Air-gapped	A system or network that is physically isolated from other networks and the internet to prevent unauthorized access.	An air-gapped computer in a research lab stores susceptible data to ensure it remains inaccessible to outside networks.
Availability	The degree to which a system remains accessible and operational over time.	A cloud provider guarantees 99.9% availability for its services, minimizing the risk of downtime for its users.
Centralized versus decentralized	Centralized systems manage resources from a single point, while decentralized systems distribute control across multiple locations or nodes.	A company shifts from a centralized database to a decentralized blockchain-based system for improved security and redundancy.
Cloud	A model that enables on-demand access to shared computing resources such as servers, storage, and applications over the internet.	A company moves its data storage and applications to the cloud, allowing employees to access resources remotely while the cloud provider manages the infrastructure.
Containerization	A lightweight method of virtualizing applications, where each container runs independently but shares the host system's kernel.	Developers use Docker containers to deploy applications consistently across multiple environments without worrying about system differences.
Cost	The financial expenditure required to build, operate, and maintain IT infrastructure.	Moving workloads to the cloud reduces the company's infrastructure costs by minimizing hardware purchases and maintenance.
Ease of deployment	Refers to how easily and quickly an application or infrastructure can be set up and configured.	A startup chooses a cloud-based infrastructure because it is easy to deploy. It can get its service online within hours.
Ease of recovery	The simplicity and speed of restoring systems to regular operation following a failure or attack.	A company that uses automated backups experiences easy recovery after a ransomware attack, restoring its data quickly.
Embedded systems	Specialized computing systems are designed to perform dedicated tasks within a more extensive system, often with real-time constraints.	Modern automobiles use embedded systems to manage engine control, braking, and entertainment features.
High availability	The ability of a system to remain operational with minimal downtime, even in the event of hardware or software failures.	An e-commerce platform implements high availability strategies, such as redundant servers, to ensure customers can shop 24/7 without interruption.
Hybrid considerations	Combining private and public cloud environments requires careful integration, security, and data consistency management.	A business uses a hybrid cloud setup to keep sensitive data on-premises while using public cloud services for less critical workloads.
Inability to patch	A scenario where a system cannot be updated with patches due to technical limitations, often leaving vulnerabilities unaddressed.	Legacy industrial control systems often face the inability to patch, exposing them to security risks.

Term	Definition	Contextual Example
Industrial Control Systems (ICS)/SCADA	A system used for controlling industrial processes, typically critical infrastructure like power plants or manufacturing lines.	A power grid operator uses SCADA systems to monitor and control power distribution across the network in real time.
Infrastructure as Code (IaC)	A method of managing and provisioning computing infrastructure through machine-readable configuration files rather than manual processes.	Developers use IaC tools like Terraform to automate the deployment of servers and applications across multiple cloud environments.
IoT	Refers to the interconnected devices that collect, transmit, and act on data across a network without human interaction.	Smart homes use IoT devices like thermostats and security cameras, allowing homeowners to control systems remotely via smartphones.
Logical segmentation	The practice of dividing a network into separate segments at the logical level, typically using firewalls or VLANs to limit access and enhance security.	A healthcare organization logically segments its patient data network from its administrative network to reduce the risk of breaches.
Microservices	An architectural style involves breaking down an application into more minor, independent services that communicate over a network.	A banking app uses microservices, allowing different teams to work on payments, user profiles, and notifications without affecting the entire system.
On-premises	Refers to IT infrastructure hosted and managed within a company's physical location rather than being outsourced to the cloud.	A financial institution maintains its data centers on-premises to meet strict regulatory requirements for data privacy.
Patch availability	The existence and readiness of software updates that fix vulnerabilities or bugs in a system.	A software company ensures patch availability for its application to fix security issues and maintain user trust quickly.
Physical isolation	A network security practice that keeps critical systems physically separate from other networks to prevent unauthorized access.	A military organization employs physical isolation to keep its classified network air-gapped from the internet.
Real-Time Operating System (RTOS)	An OS designed to process data in real time ensures predictable and timely input responses.	Medical devices like pacemakers rely on RTOS to process inputs and respond instantly to critical patient data.
Resilience	The capacity of a system to recover quickly from disruptions or failures.	A telecom company builds resilience into its network with backup systems and automated failover processes.
Responsibility matrix	A framework that defines the division of responsibilities between a cloud provider and the customer, typically related to security and operations.	The provider is responsible for securing the physical infrastructure in a cloud environment while the customer secures their data and access controls.
Responsiveness	The speed at which a system responds to user inputs or requests.	A mobile banking app prioritizes responsiveness to provide users with quick access to account balances and transactions.
Risk transference	The act of transferring risk to another party, often through insurance or outsourcing responsibilities.	A company adopts a cloud service provider, transferring some risks associated with managing physical infrastructure to the provider.
Scalability	The ability of a system to handle increased demand or workloads by adding resources without affecting performance.	An online video streaming service scales its infrastructure during peak hours to handle millions of simultaneous viewers.
Serverless	A cloud-computing model where the cloud provider manages the infrastructure and automatically scales resources as needed, based on demand.	An e-commerce site uses serverless computing to handle traffic spikes during sales events, only paying for the resources used.
Software-Defined Networking (SDN)	A networking approach that uses software to manage and control network resources dynamically, allowing for more flexibility and automation.	A large enterprise adopts SDN to streamline network traffic management and improve scalability for its growing infrastructure.
Third-party vendors	External providers that deliver services, such as cloud computing or software, often require additional risk and security management.	A company partners with a third-party vendor to host their customer service platform, ensuring the vendor meets security compliance.
Virtualization	The process of creating virtual instances of physical hardware, such as servers or storage, to increase efficiency and scalability.	A company virtualizes its servers to reduce hardware costs and optimize resource utilization.

Given a scenario, apply security principles to secure enterprise infrastructure

Term	Definition	Contextual Example
802.1X	A port-based network access control protocol that authenticates devices before allowing them onto a network.	A university implements 802.1X on its campus network, requiring students to authenticate before gaining internet access.
Active versus passive	Active devices interact with network traffic, such as filtering or routing, while passive devices monitor traffic without altering it.	An active firewall filters traffic, while a passive network sensor only logs activity for analysis.
Attack surface	The total number of points an attacker could attempt to exploit a system, including software, hardware, and network vulnerabilities.	A company reduces its attack surface by turning off unused ports and services on its web servers.

Term	Definition	Contextual Example
Connectivity	Refers to the state and methods through which network devices are linked and communicate.	An office connects its local network to the cloud through a VPN, ensuring secure data transfers.
Device placement	The strategic positioning of devices such as routers, firewalls, and switches within a network to optimize performance and security.	A company's firewall is placed between the internet and the internal network to block unauthorized traffic.
Extensible Authentication Protocol (EAP)	A framework that supports multiple authentication methods, including passwords, certificates, and token-based authentication.	A wireless network uses EAP for secure authentication between devices and access points.
Fail-closed	A failure mode in which, if a security system fails, it defaults to blocking all traffic to maintain security.	A failed IDS device blocks all network traffic to prevent potential security breaches until the issue is resolved.
Fail-open	A failure mode in which if a security system fails, it defaults to allowing traffic through to avoid disrupting service.	During a firewall failure, the system allows traffic to continue to flow, ensuring operational continuity but at a security risk.
Failure modes	There are various ways a system can fail and how it behaves when it does.	A server configured with fail-closed security will block all traffic if it encounters a critical failure.
Firewall types	Various types of firewalls provide different levels of protection based on network traffic or application data.	A business uses a Web Application Firewall (WAF) to protect its website from attacks like SQL injection.
Inline versus tap/monitor	Inline devices are placed directly within the traffic path, whereas tap/monitor devices observe traffic without disrupting it.	An intrusion prevention system (IPS) operates inline to block threats, while a tap is used to monitor network traffic without affecting performance.
Internet Protocol Security (IPSec)	A suite of protocols that provides secure communication by authenticating and encrypting IP packets.	A company secures its interoffice VPN using IPSec to encrypt traffic between branch offices.
Intrusion Prevention System (IPS)/Intrusion Detection System (IDS)	IPS actively blocks malicious traffic, while IDS monitors and alerts on potential threats without intervening directly.	An IPS is configured to block known malware signatures, while an IDS generates alerts when suspicious behavior is detected.
Jump server	A specialized server is used to access and manage devices in a separate security zone, often with enhanced security controls.	Administrators use a jump server to access sensitive internal servers from a less secure network securely.
Layer 4/Layer 7 Firewall	Layer 4 firewalls filter traffic based on transport layer information (for example, IP addresses, ports), while Layer 7 firewalls inspect traffic at the application layer.	A Layer 7 firewall inspects HTTP traffic to block malicious requests targeting a web server's API endpoints.
Load balancer	A device or software that distributes network or application traffic across multiple servers to ensure optimal performance and avoid overloading any single server.	A load balancer distributes traffic across several web servers to handle high user requests during peak times.
Next-Generation Firewall (NGFW)	A firewall that goes beyond basic packet filtering by including features such as application awareness, integrated IPS, and advanced threat detection.	A corporate network uses an NGFW to monitor applications and block malware while enforcing network security policies.
Port security	Techniques and technologies are used to secure and control access to network ports, often to prevent unauthorized devices from connecting.	802.1X is enabled on the switch ports to authenticate devices before granting access to the network.
Proxy server	An intermediary server that forwards client requests to other servers is often used to anonymize traffic or improve security.	A company uses a proxy server to route web traffic, hiding the internal IP addresses from external threats.
Remote Access	The ability to connect to a network or system from a location outside the internal network, often via VPN or remote desktop solutions.	An IT administrator uses remote access software to troubleshoot server issues while offsite.
Secure Access Service Edge (SASE)	A cloud-based architecture that combines network security and wide-area networking into a single service to secure access to applications from any location.	A global enterprise uses SASE to provide secure remote access for its distributed workforce, consolidating VPN, firewall, and SD-WAN services.
Security zones	Segmented areas within a network that apply different levels of security controls, typically separating trusted, semi-trusted, and untrusted networks.	A DMZ (demilitarized zone) is a security zone between the internal network and external traffic that hosts web services.
Selection of effective controls	Choosing the most appropriate security measures to protect an organization's assets and mitigate risks.	A bank selects multi-factor authentication and encryption as adequate controls for securing customer account access.
Sensors	Devices or software used to monitor and collect data on network activity to detect anomalies or threats.	A network intrusion detection sensor monitors inbound and outbound traffic to detect unusual patterns.
Software-Defined Wide Area Network (SD-WAN)	A network management approach that uses software to manage and optimize wide-area networks, improving performance and reducing costs.	A multinational company efficiently uses SD-WAN to manage and prioritize traffic across its global branch offices.
Transport Layer Security (TLS)	A cryptographic protocol that provides secure communication over a network by encrypting data.	A web browser uses TLS to encrypt user data when connecting to secure websites, indicated by the "https" in the URL.

Term	Definition	Contextual Example
Tunneling	The practice of encapsulating one protocol within another to secure data transmission over a network.	A company uses IPSec tunneling to secure communications between its principal office and a remote data center.
Unified Threat Management (UTM)	An all-in-one security solution that integrates multiple security functions, such as firewall, antivirus, and intrusion prevention, into a single device.	A small business installs a UTM appliance to provide comprehensive protection against network threats.
Virtual Private Network (VPN)	A secure tunnel is created over a public network that encrypts data to ensure privacy and security.	Remote employees use a VPN to securely connect to the company's internal network while working from home.
Web Application Firewall (WAF)	A firewall explicitly designed to protect web applications by filtering and monitoring HTTP traffic.	An online retailer uses a WAF to block common web application attacks, such as cross-site scripting (XSS).

Compare and contrast concepts and strategies to protect data

Term	Definition	Contextual Example
Confidential data	Information is limited to a specific group of people or authorized users and must not be disclosed to the public.	Employee performance evaluations are kept confidential to protect individual privacy.
Critical data	Information vital to the operation of an organization, the loss of which could cause significant disruption.	A financial institution's transaction records are considered critical data, and backups are made frequently to prevent loss.
Data at rest	Data is stored on a physical device or in the cloud but not actively transmitted or processed.	A company encrypts its data at rest on servers to prevent unauthorized access if the storage is compromised.
Data in transit	Data that is actively being transferred from one location to another, such as across networks.	Secure email services encrypt data in transit to ensure that messages remain confidential while being sent.
Data in use	Data that is actively being processed by an application or device.	While editing a customer's profile, the company's system encrypts the data to prevent unauthorized access.
Data sovereignty	The concept is that data is subject to the laws and governance structures of the country where it is located.	A global corporation stores its European customer data within the EU to comply with data sovereignty laws under GDPR.
Encryption	A method of converting data into a coded form to prevent unauthorized access.	A financial institution encrypts customer account data to ensure it remains secure, even if intercepted.
Financial information	Data related to financial transactions, assets, liabilities, and other financial records.	An online payment system encrypts all customer financial information, such as credit card numbers, to ensure secure transactions.
Geographic restrictions	Limitations are placed on where data can be accessed or processed based on location.	An online service restricts access to its data centers from specific countries to comply with local privacy laws.
Geolocation	The geographical location information of a device or data storage can impact data sovereignty and security considerations.	A cloud provider offers geolocation options, allowing companies to store data in specific regions to comply with local regulations.
Hashing	A process that transforms data into a fixed-size string of characters, usually for integrity verification purposes.	Passwords are hashed before being stored in a database, making them unreadable to unauthorized users.
Human- and non-human-readable data	Human-readable data, such as text, can be interpreted by people, while non-human-readable data, including binary code, is designed for machine processing.	Log files are considered non-human-readable data and are processed by specialized software for analysis.
Intellectual property	Creations of the mind, like inventions, designs, and artistic works, are legally protected.	A software company holds patents on its innovative algorithms as intellectual property.
Legal information	Data pertains to legal matters, such as contracts, legal advice, and case files.	A law firm securely stores client contracts and case files to protect sensitive legal information.
Masking	The process of hiding or obfuscating parts of data to protect sensitive information from unauthorized users.	A retail company uses masking to display only the last four digits of a customer's credit card number.
Obfuscation	A technique used to make data unclear or difficult to interpret to protect it from unauthorized access.	Source code obfuscation is used in software to make it harder for attackers to understand the code's functionality.
Permission restrictions	Assigning specific access rights to users or systems to control who can view or modify data.	Only HR personnel have permission to access employee salary information in the database.
Private data	Individual data, such as addresses and phone numbers, is kept confidential to protect personal privacy.	An online retailer uses encryption to protect customers' private data, including home addresses.
Public data	Information can be freely shared with the public without causing harm or loss.	Government census data is often classified as public and made available to everyone.

Term	Definition	Contextual Example
Regulated data	Data that is governed by laws or regulations such as GDPR or HIPAA.	A hospital must comply with HIPAA regulations when handling patient health records.
Restricted data	Information with access limitations due to its importance or potential impact if misused.	Only senior management can access the company's restricted strategic plans for the next fiscal year.
Segmentation	The practice of dividing a network or data environment into smaller sections to limit access and reduce risk.	A company segments customer data from its internal financial data to improve security controls.
Sensitive data	Information that requires protection from unauthorized access could cause harm if disclosed.	A customer's social security number is sensitive data and should be stored securely to prevent identity theft.
Tokenization	Replacing sensitive data with non-sensitive placeholders (tokens) that can be mapped back to the original data.	A payment processor tokenizes credit card numbers, which are never stored in their database.
Trade secret	Proprietary information that gives a business a competitive advantage and is kept confidential.	A company's formula for a new product is classified as a trade secret and only accessible to authorized personnel.

Explain the importance of resilience and recovery in security architecture

Term	Definition	Contextual Example
Backup encryption	The process of encoding backup data ensures it is protected from unauthorized access.	All backups are encrypted to ensure that even if the data is stolen, it cannot be accessed without the proper decryption keys.
Backup frequency	The regular interval at which data backups are performed to minimize data loss in case of failure.	A financial institution performs daily backups to ensure recent transactions are recovered during a system outage.
Capacity planning	Forecasting future infrastructure needs regarding people, technology, and resources to ensure systems can scale as needed.	An e-commerce platform plans capacity to ensure they have enough server resources during holiday sales spikes.
Clustering	Connecting multiple servers to work as a single system improves redundancy and performance.	A data center uses server clustering to ensure that if one server fails, another immediately takes over without disrupting service.
Cold site	A backup site with no active systems but where necessary infrastructure is available to set up operations after a delay.	An organization uses a cold site as a low-cost disaster recovery option, where equipment is installed only after an emergency.
Continuity of operations	Planning and implementing strategies ensures essential functions continue during and after a disaster.	A healthcare provider's continuity of operations plan ensures critical services, like patient data access, continue in case of IT failures.
Data recovery	The process of restoring lost, corrupted, or deleted data from backups.	After a ransomware attack, the company successfully restores its systems using recent data recovery backups.
Data replication	The process of copying data from one location to another in real time to ensure redundancy and availability.	A business replicates its database across multiple servers to ensure that if one server goes down, the data is still available from another.
Failover	The automatic transfer of system functions to a backup server or site if the primary system fails.	During a power outage, the company's servers automatically fail over to a backup site to maintain operations without interruption.
Generators	Devices that provide backup electrical power in the event of a power outage.	The hospital's critical systems stay operational during a power outage thanks to its backup generators.
Geographic dispersion	Spreading critical resources across different locations to minimize risk from local disasters.	A multinational company distributes its data centers across continents to protect against natural disasters or regional power failures.
High availability	A system or component can remain operational for a long time with minimal downtime.	A bank employs high availability strategies using clustering to ensure that its online services are always accessible, even during server failures.
Hot site	A fully operational backup site that can take over immediately after a disaster.	A financial institution maintains a hot site where all critical operations can be transferred instantly in case the primary site fails.
Journaling	Keeping a continuous log of transactions or changes to data ensures that operations can be restored at any time.	The database uses journaling to track all changes, enabling recovery of the exact data state at any time.
Load balancing	Distributing network or application traffic across multiple servers ensures no single server becomes overloaded.	A web service uses load balancing to distribute user traffic between different servers, ensuring a smooth experience even during peak times.
Multi-cloud systems	Using multiple cloud service providers to enhance redundancy, flexibility, and resilience.	A company employs multi-cloud systems, running applications across AWS and Azure to avoid outages on a single cloud platform.
Onsite/offsite backups	Onsite backups are stored at the exact location of the data source, while offsite backups are stored in a different physical location.	The company keeps onsite backups for quick restoration and offsite backups for disaster recovery in case of a significant event.

Term	Definition	Contextual Example
Parallel processing	Running the primary and backup systems simultaneously to ensure both remain fully functional.	The organization uses parallel processing while migrating to a new system, allowing old and new systems to run concurrently to avoid downtime.
Platform diversity	Using different technology platforms avoids relying on a single solution and increases resilience.	The IT team ensures platform diversity by using a mix of operating systems and cloud providers, reducing dependency on any one system.
Snapshots	A point-in-time copy of data that captures the state of a system or data set.	The cloud service takes daily snapshots of the database, allowing for quick recovery of specific states if needed.
Tabletop exercises	Simulated discussions of emergency scenarios to test the effectiveness of disaster recovery and business continuity plans.	The company runs tabletop exercises to review its response to a potential data breach, improving response times and identifying weaknesses.
Uninterruptible Power Supply (UPS)	A device that provides short-term power when the primary power source fails, allowing for safe system shutdown or switch to backup power.	When the office building lost power, the UPS kicked in, giving enough time to save data and safely shut down the computers.
Warm site	A backup site that has the hardware infrastructure ready but requires data and systems to be loaded before it can become operational.	The company has a warm site where the necessary systems are available, but it takes a few hours to restore full functionality after a disaster.

Domain 4:

Given a scenario, apply common security techniques to computing resources

Term	Definition	Contextual Example
AAA/Remote Authentication Dial-In User Service (RADIUS)	A protocol used for network access control, providing centralized authentication, authorization, and accounting.	The organization uses RADIUS to enforce secure, centralized authentication for users accessing the corporate network.
Application security	Practices and tools used to ensure that applications are secure from vulnerabilities and threats.	The development team focuses on application security by implementing input validation and secure coding practices.
Authentication protocols	Protocols that verify the identity of users or devices accessing a network or system.	The IT team implements authentication protocols like RADIUS to ensure that only authorized users can access the network.
Bring your own device (BYOD)	A deployment model where employees use their personal devices for work purposes.	Under the BYOD model, employees can access corporate resources on their personal devices, but security measures are enforced.
Choose your own device (CYOD)	A deployment model where employees can choose from a selection of approved devices to use for work.	Under the CYOD model, employees select from a range of company-approved devices that meet security requirements.
Cloud infrastructure	Virtualized environments that host data and applications. These environments require specific configurations for secure access.	The cloud infrastructure is hardened by applying encryption and access controls to ensure data is protected.
Code signing	A process of digitally signing software code to ensure its authenticity and integrity.	The development team uses code signing to verify that software updates have not been tampered with.
Connection Methods	Ways that mobile devices connect to networks, such as cellular, Wi-Fi, and Bluetooth.	Employees use various connection methods, such as cellular and Wi-Fi, to access corporate resources while ensuring secure configurations are in place.
Corporate-Owned, Personally Enabled (COPE)	A deployment model where the company provides devices that employees can use for both personal and work-related tasks.	In the COPE model, the company provides employees with mobile devices, which are configured with both personal and work profiles.
Cryptographic protocols	Security protocols that use encryption to protect data transmitted over networks.	The organization uses cryptographic protocols like TLS to secure communications between employees and the server.
Deployment models	Different approaches for managing mobile devices, including BYOD, COPE, and CYOD.	The company adopts the BYOD deployment model, allowing employees to use their own devices for work while maintaining security through MDM.
Embedded systems	Specialized hardware systems that perform dedicated functions, often requiring unique security considerations.	Embedded systems in medical devices are hardened by ensuring secure boot processes and regular firmware updates.
Hardening targets	Systems or devices that need to be configured to reduce vulnerabilities and enhance security.	The organization focuses on hardening targets like mobile devices and servers by removing unnecessary services and implementing security best practices.
Heat maps	Visual representations of wireless signal strength and coverage in a given area.	Heat maps are used to optimize the placement of Wi-Fi access points, ensuring even coverage across the office.
ICS/SCADA	Industrial Control Systems (ICS) and Supervisory Control and Data Acquisition (SCADA) systems that manage	ICS/SCADA systems are hardened by isolating them from the internet and applying strict access controls.

Term	Definition	Contextual Example
	critical infrastructure.	
Input validation	A security measure that ensures data entered into a system is valid and does not pose a security risk.	The application uses input validation to prevent SQL injection attacks by verifying all user inputs.
IoT devices	Internet of Things (IoT) devices, which connect to networks and require strong security measures to prevent unauthorized access.	IoT devices are hardened by changing default credentials and enabling encryption.
Mobile Device Management (MDM)	A solution for managing and securing mobile devices in an organization.	The IT department uses MDM to enforce security policies, such as encryption and remote wipe, on employee devices.
Mobile devices	Smartphones, tablets, and other portable devices requiring enhanced security controls.	The IT department hardens mobile devices by disabling unused features and enforcing encryption.
Monitoring	The continuous observation of systems and networks to detect and respond to security threats.	The security team implements monitoring tools to detect unauthorized access attempts and anomalous activities in real time.
Routers	Devices that forward data between networks and must be secured to prevent unauthorized access.	Routers are hardened by changing default passwords and using encrypted communication protocols.
Real-Time Operating Systems (RTOS)	Operating systems designed to manage real-time applications with strict timing constraints.	RTOS devices are hardened by applying security patches and restricting access to critical resources.
Sandboxing	A security technique that isolates running programs to prevent them from affecting other parts of the system.	The IT team uses sandboxing to test untrusted applications in a secure environment without risking the entire network.
Secure baselines	Standardized configurations that ensure systems are secure and compliant by default.	The company establishes secure baselines for all servers, specifying necessary configurations like encryption and access controls.
Secure cookies	Cookies that are transmitted over secure channels and have security flags to prevent unauthorized access.	The web application uses secure cookies with the "HttpOnly" and "Secure" flags to protect session data.
Site surveys	Assessments of a physical location to determine optimal placement of wireless devices for coverage and security.	The IT team performs site surveys to identify ideal locations for installing wireless access points.
Static code analysis	The process of reviewing application source code for security vulnerabilities without executing the code.	The security team conducts static code analysis to identify vulnerabilities before deploying the application.
Switches	Network devices that connect different parts of a network. These devices require strong security measures.	Switches are hardened by disabling unused ports and enabling port security to prevent unauthorized access.
Wi-Fi Protected Access 3 (WPA3)	A security protocol for Wi-Fi networks that provides stronger encryption and protections than previous versions.	The company upgrades its wireless networks to WPA3 to ensure enhanced encryption and prevent unauthorized access.
Wireless devices	Devices that connect to networks wirelessly, requiring secure configuration and setup.	Wireless devices are configured with encryption and strong authentication methods to prevent unauthorized access.
Wireless security settings	Configurations that enhance the security of wireless networks, such as WPA3 and RADIUS.	The organization configures wireless security settings like WPA3 and RADIUS to secure employee Wi-Fi connections.
Workstations	Computers used by employees for daily tasks, which need to be secured against vulnerabilities.	Workstations are hardened by disabling unnecessary ports and services and applying security patches.

Explain the security implications of proper hardware, software, and data asset management

Term	Definition	Contextual Example
Acquisition/Procurement process	The process of acquiring or purchasing assets, including hardware, software, and services, ensuring compliance with security and business requirements.	The company follows a structured procurement process to acquire new servers, ensuring they meet the organization's security policies and compliance with industry standards.
Assignment/Accounting	The process of assigning ownership and tracking accountability for assets throughout their lifecycle, ensuring proper usage and security.	Each asset within the organization, such as laptops and servers, is assigned to a specific department or individual to ensure accountability for its maintenance and security.
Classification	The process of categorizing assets based on their importance, sensitivity, or value to the organization, which influences security and access control measures.	Sensitive customer data stored on company databases is classified as "Confidential," requiring strict access control and encryption to prevent unauthorized access.
Data retention	The policies and practices for securely storing data over a defined period before it is deleted or archived, often in compliance with legal and organizational requirements.	The company adheres to a data retention policy that mandates customer data be retained for five years before it can be securely archived or permanently deleted.
Destruction	The physical destruction of an asset, such as shredding hard drives or burning documents, to ensure all data is irretrievably lost.	After sanitizing the data, old hard drives are physically destroyed using an industrial shredder to ensure complete data destruction and prevent data recovery attempts.

Term	Definition	Contextual Example
Disposal/Decommissioning	The process of securely removing or retiring assets that are no longer in use, ensuring data is safely handled during the process.	The company follows a formal decommissioning process for old servers, ensuring they are wiped of all data before being physically dismantled and disposed of securely.
Enumeration	The process of cataloging and identifying all assets within a network or organizational infrastructure to ensure proper management and security.	Network administrators conduct device enumeration across the corporate network to identify all connected systems and ensure they adhere to security policies.
Inventory	A comprehensive list or database of all assets owned by the organization, including hardware, software, and digital resources.	The organization conducts quarterly inventory audits to ensure all devices, including servers, workstations, and mobile devices, are properly accounted for and recorded.
Monitoring/Asset tracking	The continuous tracking and management of assets to ensure their location, usage, and security are maintained over time.	The IT department uses asset management software to track the physical location and status of all company-issued laptops, ensuring they remain compliant with security policies.
Ownership	The individual or department responsible for managing, maintaining, and securing a particular asset throughout its lifecycle.	The IT department assigns a specific server to the network administration team, making them responsible for its security, maintenance, and updates.
Sanitization	The process of securely erasing all sensitive data from an asset before it is decommissioned, sold, or repurposed, ensuring no data recovery is possible.	Before decommissioning old hard drives, the organization uses specialized data-wiping tools to sanitize the drives, ensuring no residual data can be recovered.

Explain various activities associated with vulnerability management

Term	Definition	Contextual Example
Application security	Practices and tools used to secure applications by identifying vulnerabilities during development and after deployment.	Developers conduct static and dynamic analyses of their code to find potential security vulnerabilities before releasing the application.
Audit	A formal review to confirm that remediation efforts and security controls meet compliance and policy requirements.	The organization conducts an audit to ensure all systems comply with internal security policies and industry regulations.
Bug bounty program	A program where organizations offer rewards to individuals who discover and report security vulnerabilities.	The organization runs a bug bounty program, offering financial rewards to security researchers who report vulnerabilities in their applications.
Common Vulnerability Enumeration (CVE)	A publicly available list of known security vulnerabilities, each assigned a unique identifier for tracking and referencing.	The IT team references CVE identifiers to quickly research and patch known vulnerabilities in the company's software.
Common Vulnerability Scoring System (CVSS)	A standardized method for assessing the severity of security vulnerabilities, providing a score to help prioritize remediation efforts.	The company uses CVSS to score vulnerabilities and prioritize patching based on the potential impact of each vulnerability.
Compensating controls	Alternative security measures implemented when the primary control is not feasible or sufficient to mitigate a vulnerability.	Instead of immediate patching, the security team uses compensating controls such as firewall rules to mitigate the risk of an unpatched system vulnerability.
Dark web	A part of the internet that is not indexed by search engines, often used for illegal activities, where security threats can originate.	The security team monitors the dark web to identify if any company credentials or sensitive data have been leaked.
Dynamic analysis	The process of testing an application by executing it and monitoring its behavior for vulnerabilities.	During dynamic analysis, testers run the web application and monitor for security breaches like unauthorized data access.
Environmental variables	Factors that affect the severity or likelihood of exploitation of a vulnerability, such as network configuration or organizational setup.	The organization's use of cloud infrastructure adds environmental variables that could increase the complexity of addressing certain vulnerabilities.
Exceptions and exemptions	Situations where certain vulnerabilities might not be remediated immediately due to business reasons or technical limitations, with approval from stakeholders.	Due to software compatibility issues, the IT team files an exemption request to delay patching a system, providing an alternative mitigation plan.
Exposure factor	The percentage of potential loss a company might face if a particular asset is compromised due to a vulnerability.	The company assesses the exposure factor of its customer database to understand the financial impact of a potential data breach.
False negative	A situation where a vulnerability or threat is not detected by security tools or processes.	The security team's scan misses a critical vulnerability, leading to a false negative that could be exploited by attackers.
False positive	A security alert or vulnerability detection that is incorrectly identified as a threat when it is not.	A vulnerability scanner flags a system as vulnerable due to a configuration setting, but further analysis reveals it as a false positive.
Identification methods	Techniques and tools used to discover potential security vulnerabilities and threats in systems and applications.	The organization uses a vulnerability scanner to identify weaknesses in its network infrastructure that attackers could exploit.

Term	Definition	Contextual Example
Industry/organizational impact	The potential consequences of a vulnerability or security incident on an organization's operations and reputation.	A vulnerability in the company's payment system could have a severe organizational impact, leading to financial losses and damage to customer trust.
Information-sharing organization	An entity that facilitates the sharing of threat intelligence and vulnerabilities between different organizations to enhance security awareness.	The company participates in an information-sharing organization to stay updated on industry-specific security threats and solutions.
Insurance	A financial strategy where an organization purchases cybersecurity insurance to cover potential losses from security incidents.	The company invests in cybersecurity insurance to mitigate financial losses in case of a significant data breach.
Open-Source Intelligence (OSINT)	Intelligence collected from publicly available sources to identify security threats and vulnerabilities.	The security team uses OSINT to monitor forums and social media for any public discussions about exploits that could target the company's systems.
Package monitoring	The process of tracking and analyzing third-party software packages for security issues and vulnerabilities.	The security team monitors third-party libraries used in applications to ensure they don't introduce vulnerabilities.
Patching	The process of updating software or systems to fix security vulnerabilities and improve functionality.	After a vulnerability is found in a critical system, the IT team applies a patch released by the software vendor to resolve the issue.
Penetration testing	A simulated attack on a system or network to identify security vulnerabilities that could be exploited.	The organization hires ethical hackers to perform penetration testing on their network to find and fix vulnerabilities before attackers can exploit them.
Proprietary/third-party	Information about threats gathered from external commercial sources or third-party services.	The company subscribes to third-party threat intelligence services to receive alerts on newly discovered vulnerabilities.
Rescanning	Running another scan after remediation to confirm that vulnerabilities have been resolved.	The security team rescan the network after patch deployment to verify that no critical vulnerabilities remain.
Responsible disclosure program	A process by which organizations allow individuals to report security vulnerabilities in a legal and ethical manner.	The company has a responsible disclosure program in place, allowing security researchers to report vulnerabilities directly to the security team.
Risk tolerance	The level of risk an organization is willing to accept when managing vulnerabilities, balanced against business needs and costs.	Due to high risk tolerance, the company decides not to patch a low-severity vulnerability immediately, focusing on more critical security concerns first.
Segmentation	Dividing a network into smaller segments to reduce the spread of threats and limit the impact of a security breach.	The organization segments its internal network, isolating sensitive systems from other areas to prevent the spread of malware.
Static analysis	Examination of code without executing it to identify vulnerabilities or security flaws.	The development team performs static analysis before running the application to detect common coding issues, such as SQL injection vulnerabilities.
System/process audit	An independent review of systems and processes to ensure compliance with security policies and identify potential vulnerabilities.	The company undergoes a regular system audit to verify that its security practices are effective and compliant with industry standards.
Threat feed	A data source providing information on emerging threats and vulnerabilities is often used to stay informed of potential security risks.	The organization subscribes to a threat feed that alerts them to the latest vulnerabilities identified in operating systems and applications.
Validation of remediation	The process of verifying that a vulnerability has been successfully addressed after remediation efforts have been completed.	After applying patches, the security team performs validation to ensure that all identified vulnerabilities have been effectively remediated.
Vulnerability classification	The categorization of vulnerabilities based on their type, severity, and potential impact.	The security team classifies vulnerabilities into categories such as network, application, or physical security weaknesses to better manage responses.
Vulnerability response and remediation	Actions taken to address identified vulnerabilities, including fixing, mitigating, or managing the associated risks.	The company deploys patches and implements network segmentation to remediate vulnerabilities found in its infrastructure.
Vulnerability scan	Automated process of scanning systems and networks for known vulnerabilities that attackers could exploit.	A vulnerability scan reveals outdated software versions on the company's servers, which can pose security risks.

Explain security alerting and monitoring concepts and tools

Term	Definition	Contextual Example
Agents/agentless	Monitoring tools can either use agents (software installed on the target system) or be agentless, which allows them to monitor	The company uses agentless monitoring tools to track the performance of cloud infrastructure without installing

Term	Definition	Contextual Example
	remotely without installing software.	software on the virtual machines.
Alert response and remediation/validation	The process of addressing and verifying the resolution of security alerts generated by monitoring systems.	When an alert is triggered for suspicious activity, the security team responds by quarantining the affected system to prevent further compromise.
Alert tuning	Adjusting the configuration of monitoring systems to reduce false positives and ensure relevant alerts are generated.	The security team tunes their SIEM system to avoid generating alerts for low-priority events, focusing on critical threats instead.
Alerting	The automated generation of notifications when specific events or anomalies are detected during monitoring activities.	When the network traffic exceeds normal thresholds, the monitoring system triggers an alert to notify the IT team.
Archiving	Storing logs, reports, and other monitoring data for future reference, compliance, or auditing purposes.	The company archives security logs for one year to meet regulatory compliance requirements.
Benchmarks	Industry standards or best practices used as reference points to measure system security and performance.	The IT team compares system configurations against security benchmarks to ensure compliance with best practices.
Data loss prevention (DLP)	Tools and processes that detect and prevent the unauthorized transfer or access of sensitive data.	The company uses DLP software to prevent employees from accidentally sharing confidential files via email.
Log aggregation	The process of collecting and storing logs from various systems and applications in a centralized location for analysis and monitoring.	The organization uses a log aggregation tool to centralize all security logs, making it easier to identify suspicious activities.
NetFlow	A network protocol used to collect and analyze IP traffic data to monitor bandwidth usage and detect anomalies.	The IT team uses NetFlow to monitor network traffic patterns and detect any unusual or suspicious activity that can indicate a potential security threat.
Quarantine	Isolating an infected or compromised system to prevent the spread of malware or security breaches.	Upon detecting malware on a workstation, the IT team quarantines the system to avoid spreading the infection across the network.
Security Content Automation Protocol (SCAP)	A suite of standards used to automate vulnerability management and compliance processes.	The security team uses SCAP to ensure all systems comply with security policies and are patched against known vulnerabilities.
Security Information and Event Management (SIEM)	A system that provides real-time analysis of security alerts and logs from different sources to detect and respond to threats.	The organization uses a SIEM solution to collect and analyze logs from various systems, helping to identify potential security breaches.
Simple Network Management Protocol (SNMP) traps	Notifications sent by network devices using SNMP to alert administrators about certain events, such as hardware failures.	When a switch experiences a failure, it sends an SNMP trap to the monitoring system, alerting the network team.
Vulnerability scanners	Tools used to scan systems, networks, and applications for known security vulnerabilities that could be exploited.	The organization runs regular vulnerability scans to identify unpatched software and configuration issues that could lead to security breaches.

Given a scenario, modify enterprise capabilities to enhance security

Term	Definition	Contextual Example
Access lists	Lists that specify which users, systems, or services are allowed or denied access through a firewall.	An access list is configured to allow only trusted employees to access sensitive financial data on the company's network.
Agent-based	Web filtering that is performed by software agents installed on individual devices to enforce browsing policies locally.	Employees working remotely have agent-based web filters installed on their laptops to block access to unapproved websites.
Block rules	Predefined policies that specify which websites or types of content should be blocked based on URL, IP address, or content category.	Block rules are configured to prevent employees from accessing high-risk sites that are flagged for hosting malware or conducting phishing attacks.
Centralized proxy	A network-based web filter where all traffic is directed through a proxy server, enforcing browsing policies centrally for all users.	The organization's proxy server blocks access to non-work-related websites and scans for potential malware before allowing external content to load.
Content categorization	Grouping web content into categories (such as news, entertainment, or shopping) to apply access rules accordingly.	The web filter automatically categorizes websites, blocking access to categories such as adult content while allowing educational sites.
Data Loss Prevention (DLP)	Security tools that prevent unauthorized access, sharing, or exfiltration of sensitive data from the organization.	The DLP system blocks employees from uploading confidential files to personal cloud storage services.
DNS filtering	A security technique that prevents users from accessing malicious or unauthorized websites by blocking DNS requests to those domains.	The DNS filtering service blocks requests to domains known for distributing malware or running phishing campaigns.

Term	Definition	Contextual Example
Domain-based Message Authentication, Reporting, and Conformance (DMARC)	A protocol that ensures emails are correctly authenticated and prevents email spoofing by validating the sender's domain.	DMARC is set up to reject emails that fail SPF and DKIM checks, reducing the risk of spoofed emails reaching employees.
DomainKeys Identified Mail (DKIM)	A security mechanism that adds a cryptographic signature to emails to verify the sender and maintain message integrity.	DKIM ensures that the company's outgoing emails can't be tampered with during transit, protecting against email-based fraud.
Email security	Tools and protocols designed to protect email communication from threats like phishing, spoofing, and malware.	The organization uses SPF, DKIM, and DMARC to verify the authenticity of incoming emails and prevent email spoofing attacks.
Endpoint Detection and Response (EDR)	A security system that continuously monitors endpoints, such as computers and mobile devices, to detect and respond to threats in real time.	The IT team uses EDR to identify and isolate malware infections on employee laptops before they can spread across the network.
Extended Detection and Response (XDR)	A security tool that collects and correlates data across multiple security layers (including network, endpoints, and cloud) to detect advanced threats.	XDR integrates data from firewalls, endpoint devices, and cloud services to provide a comprehensive view of the organization's security posture.
File integrity monitoring	A process for detecting unauthorized changes to critical system files or directories to ensure their integrity.	The IT department uses file integrity monitoring software to alert them if any key system files are modified or deleted.
Firewall	A network security system that monitors and controls incoming and outgoing traffic based on predefined security rules.	The firewall blocks unauthorized traffic from entering the internal company network by allowing only web traffic over HTTPS while blocking other services.
Group policy	A centralized management feature in Windows for controlling the security settings and behavior of computers and users across a network.	IT configures Group Policies to enforce password complexity rules and prevent users from installing unauthorized software on their machines.
IDS/IPS	Intrusion Detection System (IDS) monitors network traffic for suspicious activity, while Intrusion Prevention System (IPS) blocks detected threats.	The company uses IDS to detect unusual patterns in network traffic and IPS to automatically block known malicious attacks.
Implementation of secure protocols	The process of selecting and configuring secure communication protocols to protect data during transmission.	The company uses TLS for secure email transmission and SSH for encrypted server management to protect against eavesdropping and man-in-the-middle attacks.
Network Access Control (NAC)	A security solution that controls access to network resources based on compliance with predefined policies, such as device security status.	NAC ensures that only devices with updated antivirus software and the latest patches can connect to the organization's internal network.
Operating system security	Security measures applied at the OS level to protect against threats, vulnerabilities, and unauthorized access.	The company enforces strong OS security policies like automatic patching and user access control to minimize vulnerabilities in Windows and Linux servers.
Ports/protocols	The specific communication channels (ports) and communication methods (protocols) that a firewall monitors.	The IT team configures the firewall to allow HTTPS traffic through port 443 and block unencrypted HTTP traffic on port 80 to ensure secure communication.
Rules	Predefined criteria used by a firewall to permit or deny network traffic based on protocols, IP addresses, or ports.	A firewall rule is created to allow only traffic from the IT department's IP range to access the internal database server, blocking all other external connections.
Screened subnets	Subnets that are isolated by firewalls to protect internal networks from untrusted external networks, typically used in a DMZ (Demilitarized Zone).	The web server is placed in a screened subnet (DMZ) so it can interact with external clients without compromising the internal network.
SELinux	Security-Enhanced Linux, a security module for Linux systems that provides advanced access controls to prevent unauthorized changes.	SELinux is enabled on the organization's Linux servers to restrict access to sensitive directories, ensuring that only authorized users can make changes.
Sender Policy Framework (SPF)	A protocol used to verify that an email comes from an authorized mail server, reducing the risk of email spoofing.	The organization's email system uses SPF to verify that incoming emails are sent from authorized servers associated with the sender's domain.
Signatures	Predefined patterns used by IDS/IPS to recognize known attacks and vulnerabilities.	The IPS blocks a malicious payload based on a known signature associated with a common malware variant, preventing an infection.
Transport method	The method or technique used to transmit data securely across a network, such as encryption or VPN tunneling.	The company uses a Virtual Private Network (VPN) to create a secure encrypted tunnel for remote workers to access internal systems.
Trends	Patterns in network activity can indicate security threats, such as abnormal traffic spikes or repeated failed login attempts.	The IDS detects a trend of repeated failed login attempts over several hours, which could indicate a brute-force attack on the system.

Term	Definition	Contextual Example
URL scanning	The process of inspecting URLs for potentially malicious or restricted content before granting access.	The web filter scans every URL accessed by employees to block phishing sites and malware-infected domains.
User Behavior Analytics (UBA)	A technique that monitors and analyzes user behavior to identify unusual or risky actions that could indicate insider threats or compromised accounts.	The UBA system flags an employee for investigation after detecting an unusual pattern of login attempts outside of normal working hours.
Web filter	A tool that restricts access to specific websites or web content based on organizational policies, content categorization, or threat reputation.	The company uses a web filter to prevent employees from accessing social media or gaming sites during work hours, improving productivity and security.

Given a scenario, implement and maintain identity and access management

Term	Definition	Contextual Example
Access controls	Mechanisms for managing who can view or use resources within a system, including various control models like mandatory, discretionary, role-based, and attribute-based access control.	Role-based access control (RBAC) ensures that only managers can approve high-level financial transactions, while attribute-based access might allow access based on user location.
Attestation	The process of verifying that a system or user meets predefined security requirements, often used in access control.	A system performs attestation to ensure a user's device is compliant with security policies before granting network access.
Attribute-based Access Control (ABAC)	Access decisions based on attributes such as user roles, device type, location, and time.	A user can access certain resources only if they are using a company-issued device, are within the office, and have manager-level clearance, following ABAC principles.
Biometrics	Authentication based on a user's unique biological characteristics, such as fingerprints or facial recognition.	Employees use fingerprint scanners to log into their workstations, adding an additional layer of security beyond passwords.
Discretionary Access Control (DAC)	A model where the resource owner has the ability to control access to their own resources.	A file owner can grant read, write, or execute permissions to other users at their discretion in a DAC-based system.
Ephemeral credentials	Temporary credentials that are automatically created and expire after a set period, minimizing the risk of long-term misuse.	Cloud systems use ephemeral credentials that expire after 15 minutes, reducing the risk of abuse if credentials are compromised.
Federation	A system that enables multiple organizations or domains to share authentication and authorization data.	Employees of partner organizations can log into the company's services using their own company credentials through a federated identity system.
Hard/soft authentication tokens	Physical (hard) or digital (soft) devices used to generate one-time authentication codes for accessing systems.	A hardware token generates a code that employees use to verify their identity when logging into sensitive systems.
Identity proofing	The process of verifying that a user is who they claim to be before granting them access to systems or resources.	New employees are required to provide government-issued IDs and complete a background check as part of identity proofing during the onboarding process.
Interoperability	The ability of different systems, applications, and devices to work together and share information securely.	The company ensures that their cloud service can integrate with external partner tools by ensuring system interoperability through the use of APIs and shared protocols.
Just-in-time permissions	A method of granting temporary, elevated access to critical systems only when needed, reducing the risk of misuse.	System administrators are granted just-in-time access to make emergency changes to the network, with their access automatically revoked once the task is complete.
Least privilege	The principle of providing users with the minimum level of access necessary to perform their job functions.	A junior developer is given read-only access to the production database, ensuring they can review data without making changes.
Lightweight Directory Access Protocol (LDAP)	A protocol used to access and maintain distributed directory information services over a network.	LDAP is used to authenticate users within a centralized directory service, allowing employees to access various internal resources without separate logins.
Mandatory Access Control (MAC)	A security model where access to resources is strictly regulated by the system based on predefined policies.	In a classified government network, only users with the necessary security clearance can access certain documents, as enforced by MAC policies.
Multifactor authentication (MFA)	An authentication method that requires users to provide two or more verification factors to gain access to a resource.	An employee logs into the company system using their password (something they know) and a security token generated by their mobile device (something they have).
Open Authorization (OAuth)	An open standard for token-based authentication that allows users to grant third-party services access to their resources without sharing credentials.	A user grants a third-party app access to their email account via OAuth without giving the app their actual login details, securing the process.
Password best practices	Guidelines that enhance the security of password usage, such as increasing length, avoiding reuse, and setting expiration dates.	Employees are required to update their passwords every 90 days and cannot reuse the last five passwords they've used.

Term	Definition	Contextual Example
Password concepts	Best practices and tools for managing and securing passwords in an organization, including complexity, reuse, and expiration policies.	The IT department enforces a password policy requiring at least 12 characters, mixed case, and the inclusion of special characters to strengthen password security.
Password managers	Tools that store and manage passwords securely for users, often generating strong passwords and auto-filling them when needed.	Employees are encouraged to use password managers to securely store their complex work-related passwords.
Password vaulting	Storing and managing sensitive passwords for privileged accounts in a secure, encrypted repository.	Password vaulting ensures that only authorized administrators can access root credentials for critical systems, and all access is logged.
Passwordless authentication	A method of verifying a user's identity without requiring a password, typically using biometrics or tokens.	The organization moves to passwordless authentication, allowing employees to log in using fingerprint scanners or security keys for easier and more secure access.
Permission assignments and implications	Assigning access rights to users based on their roles or needs, with an impact on security and system integrity.	A financial manager is granted permission to view and edit sensitive financial data, while general staff only have "View" permissions to prevent accidental data alteration.
Privileged Access Management (PAM) tools	Tools that help control and monitor access to sensitive systems or data for users with elevated privileges.	The IT team uses PAM tools to grant system administrators just-in-time access to production environments, ensuring that high-level access is temporary and tightly controlled.
Provisioning/de-provisioning user accounts	The process of creating, managing, and deleting user accounts in an organization to control access to resources.	When a new employee joins the company, an IT administrator provisions their account, assigning necessary permissions. When they leave, their account is de-provisioned to revoke access.
Role-Based Access Control (RBAC)	Access control based on a user's role within an organization, granting permissions according to the role's needs.	All employees in the sales department are automatically granted access to the CRM system, but only sales managers can approve contract changes.
Rule-Based Access Control	A system where access is governed by predefined rules, such as IP address or time of access.	Access to the server room is restricted to specific times of day using rule-based access control policies.
Security Assertions Markup Language (SAML)	An XML-based standard for exchanging authentication and authorization data between parties, particularly for SSO.	When an employee logs into the company portal via SSO, SAML is used to authenticate their identity with a third-party identity provider, granting them access.
Security keys	Physical devices that act as a second authentication factor, such as USB security keys.	A USB security key is required to complete the login process for certain high-security systems, preventing unauthorized access even if the password is compromised.
Single Sign-On (SSO)	A user authentication process that allows users to access multiple applications with one set of login credentials.	An employee logs into their email account and is automatically authenticated for access to other internal apps like the CRM and project management tools.
Time-of-day restrictions	Policies that limit when users can access certain systems or data based on the time of day.	The IT system restricts remote access to administrative tools outside of regular business hours to reduce the risk of unauthorized access.

Explain the importance of automation and orchestration related to secure operations

Term	Definition	Contextual Example
Complexity	The potential increase in system complexity resulting from automation, which can require specialized skills to manage.	Automation scripts that are overly complex can lead to difficulties in troubleshooting, requiring ongoing training for staff.
Cost	The financial implications of implementing and maintaining automation solutions, which can be significant depending on the scale and technology used.	An organization evaluates whether investing in automation tools will result in long-term operational cost savings compared to manual processes.
Efficiency/time saving	The reduced time and effort required to complete tasks through automation leads to increased productivity.	By automating report generation, an organization saves several hours each week so that employees can redirect towards more critical analyses.
Employee retention	Keeping employees engaged and satisfied by reducing repetitive and mundane tasks through automation, leading to higher job satisfaction.	Employees can focus on innovative projects instead of mundane data entry tasks, resulting in higher job satisfaction and retention rates.
Enforcing baselines	Ensuring that security policies and standards are consistently applied across systems and processes through automation.	Automated compliance checks verify that all servers adhere to the organization's established security configuration standards.
Escalation	The process of automatically advancing unresolved issues to higher support tiers or more experienced personnel for resolution.	If a support ticket remains unresolved for over 24 hours, it is automatically escalated to a senior technician for further investigation and resolution.
Guardrails	Automated controls or checks designed to ensure compliance with security policies and prevent policy	An automated system that prevents users from accessing sensitive data unless they have the proper clearance, thereby enforcing data protection

Term	Definition	Contextual Example
	violations.	policies.
Integrations and application programming interfaces (APIs)	Utilizing APIs to automate interactions between different software applications, enabling seamless data exchange and task execution.	An automation script that updates user information across multiple applications using API calls whenever there is a change to ensure consistency across systems.
Reaction time	The speed at which organizations can respond to incidents or changes enhanced through automation.	Automated alerts notify the security team of potential threats in real time, enabling quicker responses to mitigate risks.
Resource provisioning	The automated assignment of computing resources, such as storage, memory, and processing power, to users or applications based on predefined criteria.	A cloud service automatically allocates additional storage space for a department when their usage reaches a certain threshold, ensuring no disruption in their operations.
Scaling in a secure manner	The ability to grow infrastructure while applying security measures automatically to protect against potential risks.	As user demand increases, additional resources are automatically provisioned in the cloud, and security policies are applied to these resources to maintain compliance.
Security groups	Collections of users or devices that share the same security policies, making it easier to manage permissions and access control.	A security group for the finance team allows members to access financial applications while restricting access to sensitive financial data for other departments.
Single point of failure	A potential risk where a single failure point in an automated process could lead to a complete system failure or loss of functionality.	If the automation tool that provisions user accounts fails, no new employees can be onboard until the issue is resolved, potentially disrupting operations.
Standard infrastructure configurations	Maintaining uniformity in system setups to ensure security and operational effectiveness, facilitated by automated processes.	New servers are automatically configured with security settings defined in templates to ensure consistency and reduce the risk of human error during setup.
Technical debt	The future costs associated with taking shortcuts or making compromises in automation that might require rework or additional effort later.	An organization that opts for quick automation solutions might face the need to revise those solutions later, incurring more costs and effort than if they had implemented robust processes initially.
Ticket creation	The automated process of generating support tickets for incidents or requests allowing for efficient tracking and management of issues.	An automated system creates a support ticket whenever a user reports an issue via email, ensuring that IT can promptly track and respond to the problem.
Use cases of automation and scripting	Scenarios in which automation and scripting are applied to streamline processes, reduce manual effort, and improve efficiency.	Automating the process of user provisioning ensures that new hires are automatically assigned necessary access rights and resources on their first day of work.
User provisioning	The process of creating, managing, and deactivating user accounts and permissions in an automated manner to ensure timely access to resources.	When a new employee is onboarded, their user account is automatically created, and they receive access to essential applications like email and project management tools.
Workforce multiplier	The concept of increasing the effectiveness of a workforce through automation, allowing fewer staff to achieve greater results.	A small IT team can manage a complex infrastructure effectively due to automation tools, maximizing productivity without needing additional hires.

Explain appropriate incident response activities

Term	Definition	Contextual Example
Acquisition	The process of collecting and securing data and evidence from systems involved in an incident while maintaining integrity and chain of custody.	During a forensic investigation, investigators create bit-by-bit copies of hard drives to preserve original data for analysis while ensuring evidence integrity.
Analysis	The evaluation of detected incidents to understand their nature, scope, and impact, enabling informed decision-making for response actions.	After detecting an anomaly, the team analyzes logs and metrics to determine whether it indicates a security breach or a benign event.
Chain of custody	The documented process of maintaining and handling evidence to ensure its integrity and admissibility in legal proceedings, tracking its transfer and storage.	Properly documenting each time evidence is accessed or transferred during an investigation ensures the chain of custody remains intact for legal purposes.
Containment	Actions taken to limit the impact of a security incident and prevent further damage or data loss.	During a malware outbreak, the IT team isolates affected systems from the network to stop the spread of the infection.
Detection	The process of identifying and recognizing potential security incidents through monitoring and analysis of systems and data.	Implementing a security information and event management (SIEM) system that alerts the security team to unusual network activity indicating a possible breach.
Digital forensics	The application of forensic techniques to collect, preserve, and analyze electronic data in support of investigations related to security incidents.	A digital forensics team retrieves and analyzes logs from compromised servers to understand the scope of a data breach and collect evidence for potential legal proceedings.
Eradication	The process of removing the cause of a security incident from the environment to prevent recurrence.	After confirming a breach, the security team identifies and removes the malicious software used by the attackers to regain control of the systems.

Term	Definition	Contextual Example
Legal hold	The process of preserving relevant information and data for legal purposes, preventing alteration or deletion during an investigation or litigation.	An organization places a legal hold on all data related to a security breach to ensure that evidence is preserved for any potential legal actions.
Lessons learned	The review and analysis conducted post-incident to identify what worked well and what can be improved in the incident response process for future events.	After a security incident, the team holds a meeting to discuss the response's effectiveness and updates their incident response plan based on the findings.
Preparation	The initial phase of the incident response process, focusing on planning, training, and establishing the necessary resources and protocols to handle potential incidents.	Conducting training sessions for the incident response team to familiarize them with their roles and responsibilities before an incident occurs.
Process	The series of steps taken to respond to and manage security incidents effectively, ensuring that the organization can recover while minimizing damage.	An incident response plan outlines the process from preparation to recovery, detailing how to manage a security breach efficiently.
Recovery	The phase of restoring affected systems and data to normal operations following an incident, ensuring that systems are clean and secure before returning to service.	After eradicating a threat, the organization restores data from backups and conducts thorough testing to confirm systems are functioning correctly before going live.
Reporting	The documentation and communication of incident details, findings, and response actions taken to relevant stakeholders for accountability and future reference.	After an incident, the incident response team compiles a detailed report outlining the timeline of events, actions taken, and recommendations for future prevention.
Root cause analysis	A systematic process of identifying the underlying causes of incidents to prevent future occurrences by addressing vulnerabilities.	After a data breach, the security team conducts a root cause analysis to determine how the attackers gained access and what security measures failed.
Simulation	A practical exercise that mimics real-world incidents, allowing teams to practice their responses in a controlled environment and evaluate their effectiveness.	Running a simulated ransomware attack where teams must respond to a series of challenges to practice their incident response skills.
Tabletop exercise	A discussion-based exercise where team members review and discuss their responses to simulate incident scenarios to identify strengths and weaknesses in their processes.	Organizing a tabletop exercise involving senior management to discuss their roles during a data breach and evaluate the organization's communication plan.
Threat hunting	The proactive search for indicators of compromise within the organization's network and systems to identify and mitigate potential threats before they cause damage.	Security analysts perform threat hunting by reviewing network traffic patterns to detect any suspicious activity that automated systems might miss.

Given a scenario, use data sources to support an investigation

Term	Definition	Contextual Example
Application logs	Applications create records to document events, transactions, and errors that occur during their operation. These records are useful for troubleshooting and performance monitoring.	An application log might show a series of error messages when a user attempts to access a feature that is currently down for maintenance.
Automated reports	Predefined reports generated by security tools or monitoring systems that summarize findings, trends, and metrics related to security events, compliance, or performance, facilitating easy analysis and decision-making.	A weekly automated report from a SIEM system might include statistics on detected incidents, response times, and trends in security events over the past week.
Dashboards	Visual interfaces that aggregate and display key metrics and data points from various sources, enabling real-time monitoring and analysis of security events, system performance, and compliance status.	A security operations center (SOC) dashboard displays real-time alerts, incident statistics, and system health metrics, allowing analysts to prioritize their response efforts.
Data sources	Various origins of data used for monitoring, analysis, and reporting within a security context, providing essential information for identifying vulnerabilities and tracking security events.	Data sources for security monitoring can include system logs, vulnerability scans, and threat intelligence feeds, which provide insights into an organization's security posture.
Endpoint logs	Logs from endpoint devices (such as desktops, laptops, and mobile devices) that track user activity, system events, and security incidents are crucial for endpoint security and analysis.	An endpoint log might include details about software installations, user logins, and any detected malware activities on the device.
Firewall logs	Logs generated by firewalls that track allowed and denied network traffic based on predefined rules, helping to monitor access and identify potential threats.	A firewall log entry can indicate an attempt to access a restricted port, allowing the security team to investigate further.
IPS/IDS logs	Logs generated by Intrusion Prevention Systems (IPS) and Intrusion Detection Systems (IDS) that track suspicious activities and potential security incidents based on predefined rules and anomaly detection.	An IDS log might capture an alert for a detected port scan, prompting security analysts to investigate the source of the scanning activity.
Log data	Records generated by systems, applications, and devices that provide detailed information about events, transactions, and operations within a network or system, essential for monitoring and incident response.	A firewall log capturing details of blocked incoming traffic attempts can help identify potential intrusion attempts.
Metadata	Data that provides information about other data, such as creation dates, file sizes, and access permissions, often used to categorize and manage logs and other information efficiently.	Metadata associated with log files can include timestamps, authors, and file formats, which help organize and retrieve logs during analysis.

Term	Definition	Contextual Example
Network logs	Logs generated by networking devices (such as routers and switches) that provide insights into traffic patterns, connection attempts, and network performance, crucial for network monitoring and troubleshooting.	A network log can show the volume of data transmitted to and from specific IP addresses, helping network administrators identify unusual traffic spikes.
OS-specific security logs	Security logs generated by the operating system that record authentication attempts, system events, and changes in system configuration. These logs help identify security breaches and unauthorized access.	Windows Security Event logs record user logins, failed access attempts, and changes made to system security settings, assisting in monitoring user activity.

Domain 5: Security Program Management and Oversight

Summarize elements of effective security governance

Term	Definition	Contextual Example
Acceptable Use Policy (AUP)	A document outlining the acceptable activities and restrictions for using an organization's systems and resources.	Employees must adhere to the AUP, which prohibits using company devices for unauthorized activities like personal file downloads.
Access control standards	Rules governing how access to resources and data is managed and enforced.	Access control standards ensure that only authorized personnel access the financial system using multifactor authentication.
Boards	Groups of individuals who are responsible for making high-level decisions and guiding the organization's strategic direction.	The board of directors approves the budget for a new cybersecurity initiative to enhance data protection.
Business continuity	A plan to ensure critical business operations continue during and after a disaster or major disruption.	The business continuity plan allows the company to quickly switch to remote work in case of a flood, minimizing downtime.
Centralized governance	A system where decision-making authority is concentrated within a central body or team.	The organization uses centralized governance, where the headquarters IT team makes major decisions on security controls.
Change management procedures	Specific steps and protocols for implementing changes within an organization, particularly regarding IT systems.	The IT department follows change management procedures to ensure software updates are thoroughly tested before deployment.
Committees	Smaller groups within an organization responsible for managing specific areas or tasks, such as risk management or cybersecurity.	A cybersecurity committee is formed to evaluate the organization's readiness against emerging threats.
Data controllers	Entities that determine how personal data is processed and for what purpose.	As the data controller, the company decides how customer information is collected, processed, and used for marketing.
Data custodians/stewards	Individuals who maintain the integrity, security, and availability of data within an organization.	IT administrators function as data custodians, ensuring that data is securely stored and regularly backed up.
Data owners	Individuals or entities responsible for the data and who typically make decisions about access and usage.	The department head acts as the data owner, defining who can access specific datasets within the company's CRM system.
Data processors	Entities or people that process data on behalf of the data controller.	A cloud service provider acts as a data processor, storing and managing customer data according to the controller's instructions.
Decentralized governance	A structure where decision-making is distributed across different departments or locations.	In a decentralized governance system, each regional office manages its own IT security policies and compliance requirements.
Disaster recovery	A strategy for restoring IT infrastructure and systems after a disaster to minimize data loss and downtime.	The disaster recovery team restores critical systems using backups after a cyberattack.
Encryption standards	Policies and requirements for encrypting sensitive data to protect it from unauthorized access.	The company uses AES-256 encryption for all customer data stored in its databases, following encryption standards.
Global considerations	International standards or legal obligations that impact global operations, such as GDPR for data privacy.	A multinational organization ensures compliance with global considerations like GDPR for handling personal data across EU countries.
Governance structures	The framework of authority and decision-making within an organization, which can be centralized or decentralized.	The company's governance structure includes a central board that makes key strategic decisions and committees that oversee specific operations.
Government entities	Bodies that create and enforce regulations and standards that affect how organizations operate.	A government entity mandates stricter data privacy controls for companies overseeing consumer data in the region.
Incident response	A defined process for detecting, responding to, and recovering from security incidents.	During a ransomware attack, the company activates its incident response plan to isolate affected systems and notify stakeholders.
Industry considerations	Best practices and standards specific to an industry to maintain compliance and security.	In the financial sector, industry considerations such as PCI DSS are critical for securing payment card information.
Information security policies	Guidelines and rules established to protect the integrity, confidentiality, and availability of data.	The company implements information security policies to ensure sensitive data is encrypted and access is role-based.

Term	Definition	Contextual Example
Legal considerations	Requirements or restrictions imposed by law regarding how data and systems are managed and protected.	The company consults its legal team to ensure that the new privacy policy complies with international GDPR regulations.
Local/regional considerations	Rules and guidelines specific to the location or region where an organization operates.	The firm adjusts its data retention policy to meet local regulatory requirements in different regions.
Monitoring and revision	Ongoing processes of reviewing and updating policies, procedures, and controls to ensure effectiveness.	The organization conducts regular monitoring and revision of its security policies to adapt to evolving cyberthreats.
National considerations	Legal or regulatory guidelines that must be adhered to within a specific country.	The company ensures its data storage systems comply with national laws regarding data sovereignty in the United States.
Onboarding/offboarding procedures	Processes for integrating new employees and securely removing access when they leave the organization.	HR ensures new hires have proper access through onboarding, while IT handles offboarding by revoking access when an employee exits.
Password standards	Guidelines that define the complexity, length, and frequency of password changes to enhance security.	The organization enforces password standards requiring a minimum of 12 characters, with a mix of letters, numbers, and special symbols.
Physical security standards	Measures and protocols to protect physical access to facilities, equipment, and information.	Physical security standards include badge access to secure rooms and surveillance cameras in sensitive areas.
Playbooks	Step-by-step guides detailing responses to specific incidents, such as cyberattacks or system failures.	The incident response team follows a playbook to manage and resolve phishing attacks, isolating compromised accounts and conducting forensic analysis.
Regulatory considerations	Compliance requirements imposed by external bodies such as governments or industry standards.	The healthcare provider ensures its operations comply with HIPAA regulatory requirements to protect patient data.
Software Development Lifecycle (SDLC)	A process for planning, creating, testing, and deploying software applications.	The software team follows the SDLC to ensure secure coding practices and reduce vulnerabilities in the final product.

Explain elements of the risk management process

Term	Definition	Contextual Example
Ad hoc risk assessment	A risk assessment performed in response to a specific event or situation.	After detecting unusual network activity, the IT team performs an ad hoc risk assessment to evaluate the potential threats.
Annualized loss expectancy (ALE)	The expected annual monetary loss due to a specific risk.	The ALE for phishing attacks is estimated at \$50,000, calculated based on the number of incidents and their financial impact.
Annualized rate of occurrence (ARO)	The estimated number of times a risk is expected to occur annually.	The ARO for minor software bugs is 4, meaning the company expects four incidents of minor software bugs each year.
Business impact analysis (BIA)	A process that identifies the potential effects of disruptions on business operations.	The BIA shows that a 24-hour power outage could disrupt production and lead to significant financial losses.
Conservative risk appetite	A risk strategy where the organization prefers to minimize risk exposure.	The organization adopts a conservative risk appetite, opting for tried-and-true technology solutions with minimal risk.
Continuous risk assessment	An ongoing process of identifying and assessing risks in real-time.	The company uses a continuous risk assessment tool to monitor network traffic for signs of cyberattacks.
Exception	A temporary deviation from standard risk management practices for specific circumstances.	The company allows an exception for an urgent project that bypasses standard security reviews due to tight deadlines.
Exemption	A special case where certain risks are not subject to the usual risk mitigation procedures.	The organization grants an exemption for its legacy systems that cannot be easily upgraded or patched.
Expansionary risk appetite	A strategy that involves taking on more risk to achieve growth.	A startup with an expansionary risk appetite invests heavily in new technology despite the potential for failure.
Exposure Factor	The percentage of asset loss that results from a risk event.	The exposure factor for a ransomware attack is 70%, indicating that a large portion of the company's data could be affected.
Impact	The potential consequences or damage caused by a risk event.	The impact of a prolonged system outage could result in significant financial losses and damage to the company's reputation.
Key risk indicators (KRI)	Metrics that signal the increasing likelihood or impact of a risk.	The organization uses KRI such as failed login attempts to monitor potential security threats in real time.
Likelihood	A measure of how likely it is for a risk to occur.	The likelihood of hardware failure is high for the company's older servers that are no longer under warranty.
Mean time between failures (MTBF)	The average time interval between failures of a system during operation, often used as a measure of reliability.	The MTBF for the company's new servers is currently 12 months, suggesting that, under normal operating conditions, the servers are expected to operate without failure for approximately one year between incidents.

Term	Definition	Contextual Example
Mean time to repair (MTTR)	The average time required to repair a failed system or component.	The MTTR for the company's critical servers is 4 hours, meaning the IT team is expected to restore them within that time.
Neutral risk appetite	A balanced approach to risk where neither high nor low risk is favored.	The company maintains a neutral risk appetite, carefully weighing both risks and rewards before making decisions.
One-time risk assessment	A single evaluation of risks, typically conducted for a specific project or event.	Before implementing a new customer database, the team performs a one-time risk assessment to identify potential data security risks.
Probability	The likelihood that a risk will occur.	The probability of a data breach increases as more employees work remotely without secure VPN access.
Qualitative risk analysis	A method of assessing risks based on subjective judgment, such as expert opinions or interviews.	The company conducts qualitative risk analysis through interviews with key stakeholders to assess how a data breach could affect customer trust.
Quantitative risk analysis	A numerical evaluation of risks, often involving financial metrics.	Using quantitative risk analysis, the team estimates the cost of a potential server failure at \$100,000 in lost revenue and recovery expenses.
Recovery point objective (RPO)	The maximum acceptable amount of data loss measured in time during a disruption.	The company sets an RPO of 15 minutes for its financial databases, meaning no more than 15 minutes of transaction data can be lost in the event of a system failure.
Recovery time objective (RTO)	The maximum acceptable time to restore operations after a disruption.	The RTO for the company's e-commerce platform is 2 hours, meaning it must be restored within that timeframe to avoid major revenue loss.
Recurring risk assessment	A regularly scheduled evaluation of risks to ensure continued protection.	The security team conducts recurring risk assessments every six months to update risk management strategies.
Risk acceptance	The decision to take no action to mitigate a risk and accept the potential consequences.	The company accepts the risk of minor outages during system updates, deciding that the potential downtime is manageable.
Risk analysis	The process of determining the potential impact and likelihood of identified risks.	A risk analysis reveals that while a DDoS attack on the company's website is unlikely, it would cause significant financial loss if it occurred.
Risk appetite	The overall amount of risk an organization is willing to take in pursuit of its objectives.	With a conservative risk appetite, the company avoids high-risk investments and focuses on protecting existing assets.
Risk assessment	The evaluation of identified risks based on their severity and likelihood of occurrence.	The company conducts an annual risk assessment to prioritize threats like data breaches and system downtimes based on their potential impact.
Risk avoidance	A strategy where the organization eliminates the risk entirely by not engaging in the risky activity.	The company avoids the risk of using third-party cloud storage by opting to store sensitive data in-house.
Risk identification	The process of identifying potential risks that could negatively impact an organization's operations or objectives.	During a quarterly security audit, the team identifies new risks such as unpatched software vulnerabilities and increased phishing attempts.
Risk management strategies	Methods for handling identified risks, including mitigation, avoidance, acceptance, and transfer.	The company uses a combination of risk management strategies, such as mitigating cyber risks by strengthening firewalls and transferring financial risks through insurance.
Risk mitigation	Actions taken to reduce the likelihood or impact of a risk.	The company mitigates the risk of unauthorized access by implementing multifactor authentication across all systems.
Risk owners	Individuals or teams responsible for managing specific risks.	The CIO is designated as the risk owner for technology-related threats, such as cyberattacks and system failures.
Risk register	A documented record of identified risks, their severity, and how they will be managed.	The company updates its risk register after each risk assessment, tracking new cybersecurity threats and mitigation strategies.
Risk reporting	The documentation and communication of risks and their management to stakeholders.	Risk reporting is conducted quarterly to inform executives about current risks and the effectiveness of mitigation strategies.
Risk threshold	The level of risk that an organization is willing to tolerate before requiring action.	The company sets a risk threshold for financial losses at \$100,000, meaning any potential loss exceeding this amount requires immediate intervention.
Risk tolerance	The degree of risk that an organization is willing to accept without taking actions to prevent the occurrence of that risk.	The company has a low-risk tolerance for data breaches but a higher tolerance for minor software bugs.
Risk transfer	Shifting the responsibility for managing a risk to another party, such as through insurance.	The company purchases cyber insurance to transfer the financial risk of a potential data breach.
Single loss expectancy (SLE)	The expected monetary loss for each occurrence of a risk event.	The SLE for a stolen laptop is calculated to be \$2,000, based on the cost of the hardware and lost data.

Explain the processes associated with third-party risk assessment and management

Term	Definition	Contextual Example
Agreement types	Various formal agreements that outline the terms and conditions of a business relationship between a company and a vendor.	The company signs multiple agreement types with vendors, including service-level agreements (SLA), non-disclosure agreements (NDA), and master service agreements (MSA).
Business partners agreement (BPA)	An agreement between two parties that outlines the terms for sharing business resources or services.	The BPA between the company and its payment processor defines how sensitive financial data will be overseen and protected.
Conflict of interest	A situation where a party's ability to act impartially is compromised due to personal interests or relationships.	The company reviews the relationships between its employees and potential vendors to ensure there are no conflicts of interest in the vendor selection process.
Due diligence	The thorough investigation an organization or individual conducts before entering into a formal agreement with a vendor.	As part of the vendor selection, the company performs due diligence to evaluate the vendor's financial health, legal history, and security measures.
Evidence of internal audits	Documentation showing that the vendor regularly performs internal audits of its systems and processes.	The vendor provides evidence of internal audits to demonstrate its ongoing commitment to maintaining security and compliance.
Independent assessments	Third-party evaluations of a vendor's security posture and practices.	The company relies on independent assessments, such as SOC 2 reports, to verify the vendor's security controls.
Master service agreement (MSA)	A long-term contract that outlines the general terms and conditions under which future work orders will be completed.	The MSA allows the company to enter into multiple projects with the vendor without negotiating a new contract each time.
Memorandum of agreement (MOA)	A formal agreement between two or more parties that outlines their responsibilities and expectations in a collaborative effort.	The MOA between the company and its cloud provider details each party's roles in ensuring data security and service availability.
Memorandum of understanding (MOU)	A non-binding agreement that outlines the terms and conditions of an understanding between two parties.	The company signs an MOU with a potential vendor to explore a partnership before committing to a formal agreement.
Non-disclosure agreement (NDA)	A legal contract that prohibits the sharing of confidential information.	The company requires all vendors to sign an NDA to protect its proprietary information during the vendor evaluation process.
Penetration testing	Simulated cyberattacks on a vendor's systems to identify vulnerabilities.	The company requires all potential vendors to undergo penetration testing to ensure their systems can resist real-world attacks.
Right-to-audit clause	A contract provision that grants the organization the ability to audit the vendor's processes and systems.	The vendor agreement includes a right-to-audit clause, allowing the company to verify the vendor's compliance with security standards at any time.
Rules of engagement	Guidelines that outline acceptable behavior and interactions during assessments, such as penetration tests or audits.	The company defines rules of engagement with its vendor before conducting a penetration test, specifying what systems can be assessed and the scope of the test.
Service-level agreement (SLA)	A contract that specifies the expected level of service, including performance metrics and remedies for failure to meet them.	The SLA with the vendor outlines a 99.9% uptime guarantee, with penalties if this level of service is not maintained.
Supply chain analysis	The process of identifying and assessing risks in the vendor's supply chain.	The company conducts a supply chain analysis to ensure that all vendors involved in producing its hardware components adhere to strict security standards.
Vendor assessment	The process of evaluating the risk and security posture of a vendor or third party before entering a business relationship.	Before selecting a cloud storage provider, the company performs a thorough vendor assessment, including penetration testing and a review of internal audit evidence.
Vendor monitoring	The process of continuously evaluating a vendor's performance and compliance after the contract is in place.	After signing the contract, the company regularly monitors the vendor's security practices and service levels to ensure compliance with the SLA.
Vendor selection	The process of choosing a vendor based on criteria such as security, cost, and performance.	The company's vendor selection process includes due diligence, conflict of interest checks, and a review of the vendor's compliance with industry regulations.
Work order (WO)/Statement of work (SOW)	A detailed document specifying the tasks, deliverables, and timelines for a specific project or service.	The SOW for the new software development project includes milestones, deadlines, and payment terms.

Summarize elements of effective security compliance

Term	Definition	Contextual Example
Attestation and acknowledgment	The formal confirmation that employees or third parties have read, understood, and agreed to comply with policies and regulations.	Employees sign an acknowledgment form confirming they have read and understood the company's updated compliance policies.

Term	Definition	Contextual Example
Automation in compliance monitoring	The use of software tools to automatically track and report compliance with regulatory requirements.	The organization implements automated tools to monitor compliance in real time, detecting any violations promptly.
Compliance reporting	The process of documenting and submitting reports to demonstrate adherence to legal, regulatory, and internal requirements.	The company prepares both internal and external compliance reports to ensure it meets all regulatory standards and internal policies.
Consequences of non-compliance	The penalties or adverse effects that result from failing to comply with legal, regulatory, or contractual obligations.	Failing to meet compliance requirements for customer data protection can lead to significant fines and reputational damage.
Contractual impacts	The effect of non-compliance on business contracts, which can include termination or penalties.	Non-compliance with service-level agreements (SLAs) can lead to the termination of a major contract with a key client.
Controller versus processor	The controller determines the purpose and means of processing personal data, while the processor processes data on behalf of the controller.	Under GDPR, the company acts as a data controller, while its cloud provider serves as the data processor.
Data inventory and retention	The process of cataloging and determining how long data should be kept, based on regulatory or business requirements.	The company maintains a detailed data inventory and retention schedule to ensure compliance with legal requirements.
Data subject	An individual whose personal data is collected, stored, or processed by an organization.	As a data subject, customers have the right to access and request the deletion of their personal information from the company's database.
Due diligence/care	The level of attention and caution that an organization must exercise to remain compliant with regulations and mitigate risks.	The company demonstrates due diligence by regularly updating its compliance policies and conducting security audits.
External compliance reporting	Reports submitted to regulatory bodies, partners, or third-party auditors to prove adherence to external regulations or agreements.	The company submits external compliance reports to government agencies to verify its adherence to industry-specific regulations.
Fines	Monetary penalties imposed for non-compliance with regulations or contractual obligations.	Failing to secure sensitive customer data could result in fines of up to \$1 million under privacy laws.
Global privacy laws	International laws and agreements governing data protection and privacy, often requiring organizations to adhere to multiple jurisdictional requirements.	The company adjusts its global operations to meet privacy requirements across the EU, U.S., and other regions.
Internal and external monitoring	Compliance monitoring conducted within the organization (internal) and by third parties or regulatory bodies (external).	The company combines internal audits and external assessments to ensure comprehensive compliance monitoring across all operations.
Internal compliance reporting	Reports generated within the organization to monitor compliance with internal policies and procedures.	The internal compliance team submits regular reports to management to ensure all departments follow corporate security guidelines.
Legal implications	The legal consequences of handling or misusing personal data, including local, national, and global considerations.	Failing to comply with global data protection regulations, such as GDPR, can result in legal implications for the company.
Local/regional privacy laws	Privacy laws specific to a region or local jurisdiction governing how personal data must be managed.	The company complies with California's Consumer Privacy Act (CCPA) to protect the personal information of California residents.
Loss of license	The revocation of an organization's legal or regulatory authorization to operate in a specific industry due to non-compliance.	Repeated violations of industry safety standards could lead to the loss of an operating license.
National privacy laws	Privacy regulations that apply across an entire country, such as the GDPR in the EU or the CCPA in the U.S.	The organization regularly updates its practices to comply with national privacy laws.
Ownership	The responsibility and rights associated with possessing and controlling data.	The company takes ownership of customer data and ensures its proper storage, processing, and protection.
Privacy	The right of individuals and organizations to control how their personal data is collected, used, and shared.	The company updates its privacy policy to comply with global regulations, ensuring proper data protection for its customers.
Reputational damage	Harm to an organization's public image or standing due to non-compliance or legal violations.	Non-compliance with environmental laws can cause severe reputational damage, leading to a loss of customers and investors.
Right to be forgotten	The right of individuals to request the deletion of their personal data from an organization's records.	Customers exercise their right to be forgotten, and the company deletes their personal data from its systems accordingly.
Sanctions	Legal or regulatory actions taken to restrict or penalize an organization for non-compliance.	Sanctions, including trade restrictions, could be imposed for failing to comply with export control regulations.

Explain types and purposes of audits and assessments

Term	Definition	Contextual Example
Active reconnaissance	Information gathering techniques that involve directly interacting with the target system, such as scanning ports or probing services.	During active reconnaissance, the penetration testers use network scanning tools to identify open ports and services running on the target system.
Assessment	A formal evaluation, either internal or external, to determine how well an organization meets specified criteria or standards.	The cybersecurity team completes a risk assessment to identify vulnerabilities in the company's infrastructure.
Attestation	The process of formally affirming or verifying that certain standards or requirements have been met, often through internal or external review.	The company provides attestation of its compliance with industry standards through a formal audit conducted by an independent third-party firm.
Audit committee	A group within the organization responsible for overseeing internal controls, financial reporting, and compliance with laws and regulations.	The audit committee conducts regular reviews to ensure all departments are aligned with corporate governance and compliance policies.
Compliance attestation	A formal declaration that the organization meets specific compliance requirements, usually supported by internal or external audits.	After a thorough review, the company submits compliance attestation documents to confirm adherence to regulatory standards.
Defensive penetration testing	A form of testing where the focus is on defending against simulated attacks to evaluate the effectiveness of current security measures.	The security team engages in defensive penetration testing to assess how well their intrusion detection systems perform under attack.
Examinations	A thorough review or inspection conducted by a regulatory body or external organization to assess compliance with laws or standards.	The company's data protection practices are subject to an external examination by the national regulatory authority.
External attestation	Verification of compliance or adherence conducted by an external regulatory body or independent third party.	The company completes an external attestation, confirming compliance with global data protection regulations.
Independent third-party audit	An objective audit conducted by an outside firm to verify compliance, financial accuracy, or the effectiveness of internal controls.	To maintain transparency, the company hires an independent third-party firm to audit its financial records and security protocols.
Integrated penetration testing	A comprehensive testing method that includes both offensive and defensive strategies, covering various attack surfaces.	The company employs integrated penetration testing to assess both offensive capabilities and defensive response times.
Internal attestation	The process of verifying compliance or adherence to standards within the organization, often conducted by an audit committee or self-assessments.	The audit committee performs internal attestation to confirm that all security protocols are being followed across departments.
Known environment penetration testing	A testing scenario in which the testers have prior knowledge of the system's architecture, configurations, or defenses.	The penetration testers use a known environment approach, leveraging inside information about the company's network setup to uncover weaknesses.
Offensive penetration testing	A proactive approach in which testers actively attempt to exploit vulnerabilities in a system to identify weaknesses.	The offensive penetration testing team discovers multiple exploitable vulnerabilities in the network's firewall configuration.
Partially known environment penetration testing	A testing scenario where testers have some, but not complete, knowledge of the system being tested.	The team conducts a partially known environment penetration test, where they are given limited information about the target network.
Passive reconnaissance	Information gathering techniques that do not involve directly interacting with the target, such as observing public data or network traffic.	The testers use passive reconnaissance to collect information about the target's IP addresses and open ports without triggering any alarms.
Penetration testing	A security testing method in which testers simulate attacks to identify vulnerabilities in a system or network.	The IT team conducts a penetration test to find potential weak points in the organization's security defenses before malicious actors can exploit those weak points.
Physical penetration testing	Simulated attacks that focus on physical security controls, such as building access and hardware security, to test vulnerabilities.	A physical penetration test is conducted to determine whether unauthorized personnel can gain access to restricted areas of the company's data center.
Reconnaissance	The process of gathering information about a target system or network to prepare for an attack or penetration test.	The penetration testing team spends several days in reconnaissance, gathering details about the company's network before launching their test attacks.
Regulatory attestation	Formal affirmation of compliance with legal and regulatory standards, often required by governmental agencies.	The organization submits regulatory attestation documents to the financial regulator to verify adherence to anti-money laundering laws.
Self-assessments	Internal evaluations where an organization reviews its own processes, controls, and adherence to regulations or policies.	The IT department conducts self-assessments to identify potential security vulnerabilities before the external audit.
Unknown environment	A testing scenario in which the testers have no prior knowledge of the system, also known as "black box" testing.	The unknown environment test reveals vulnerabilities that had gone undetected during previous assessments where testers had more information.

Given a scenario, implement security awareness practices

Term	Definition	Contextual Example
Anomalous behavior recognition	Identifying actions that deviate from normal patterns, potentially indicating risky or unexpected activities.	The security team detects anomalous behavior when an employee attempts to access sensitive files at unusual hours.
Hybrid/Remote work environments	Work environments where employees work both on-site and remotely, requiring additional security measures to manage the associated risks.	The organization updates its security policies to address challenges specific to hybrid and remote work environments, focusing on securing home networks.
Initial reporting	The first instance of reporting a potential threat or suspicious activity to the IT or security team.	An employee initiates reporting by alerting the security team to a suspicious email they received.
Insider threat	A threat posed by individuals within the organization, either through malicious intent or unintentional actions that compromise security.	The security team monitors user activities to identify potential insider threats, particularly from employees with access to sensitive information.
Operational Security (OPSEC)	A risk management process that protects sensitive information by identifying and addressing vulnerabilities in day-to-day operations.	The company implements operational security measures, restricting access to sensitive data to mitigate risks.
Password management	Best practices and tools used to create, store, and manage secure passwords to prevent unauthorized access.	Employees participate in password management training, learning how to create strong passwords and effectively use password managers.
Phishing campaigns	Coordinated, large-scale attempts to deceive multiple people via email, messages, or social media to gather confidential information or distribute malware.	A company faces a phishing campaign targeting multiple departments, where fake invoice requests are sent to over 500 employees.
Phishing	A cyberattack method where attackers trick individuals into revealing sensitive information by disguising themselves as trustworthy entities.	An employee receives an email appearing to be from the IT department, asking them to reset their password via a suspicious link.
Policy/Handbooks	Documents that outline acceptable behaviors, guidelines, and protocols to ensure compliance with security standards within the organization.	The organization's policy handbook clearly outlines steps employees should take when receiving suspicious emails.
Recognizing a phishing attempt	The ability to identify signs of phishing attacks, such as unusual URLs, misspellings, or requests for sensitive information.	Employees recognize a phishing attempt when they see a suspicious link in an email asking for their login credentials.
Recurring reporting	Ongoing or scheduled reporting of security incidents or updates on existing threats to ensure vigilance.	The organization establishes recurring reporting protocols, requiring employees to notify the security team of any suspicious emails they encounter.
Removable media and cables	Portable devices like USB drives, external hard drives, and cables that must be securely managed to avoid data breaches.	Employees receive guidelines on the risks associated with using unsecured removable media and the need for secure data transfer practices.
Reporting and monitoring	Processes for users to report suspicious activities or incidents and for security teams to monitor and address potential threats.	The IT team uses real-time monitoring tools to detect and respond to security incidents more efficiently.
Responding to reported suspicious messages	The process of investigating suspicious emails or messages reported by users, often by escalating them to the IT or security team.	An employee reports a suspicious email to IT, which then investigates and confirms it as a phishing attempt.
Risky behavior	Actions that pose a potential security risk, such as downloading unverified software or clicking on untrusted links.	An employee engages in risky behavior by downloading software from an unknown source, raising a security alert.
Situational awareness	Being aware of one's environment and recognizing potential threats or vulnerabilities in real time.	Employees improve their situational awareness during training, learning to spot social engineering tactics.
Social engineering	A tactic where attackers manipulate individuals into divulging confidential information or performing actions that compromise security.	An employee encounters social engineering when a caller pretends to be from IT support, attempting to extract login credentials.
Unexpected behavior	Unusual activities for a user or system based on previous patterns that might indicate a potential security threat.	A system flags unexpected behavior when a user logs in from a different country during off-hours.
Unintentional behavior	Actions that can lead to security risks without the user realizing it, such as accidentally sharing sensitive information with the wrong recipient.	An employee unintentionally sends sensitive data to the wrong email address.
User guidance and training	Structured efforts to educate users on cybersecurity best practices, including policies, situational awareness, and threat prevention.	The organization conducts training sessions to help employees recognize and respond to phishing attacks effectively.

Next steps

Refer to this comprehensive list of terms, definitions, and examples as you prepare for your practice exam questions and in conjunction with other study materials. Also consider studying with a companion who can quiz you on this terms definitions and contextual examples as part of your exam preparations.

Author(s)

[Manish Kumar](#)



Skills Network